

Roadmaps und Arbeitspakete

Meilensteinplanung M0 bis M9, Arbeitspakete und Backlog

Die Planungsebene: konsolidierte Roadmaps für AI-Agent, SystemAdmin, Marketing, Security-Hardening und Marktdaten, die geschnittenen Arbeitspakete sowie Backlog und Koordinations-Claims. Dieses Bündel erzählt, wohin sich die Plattform entwickelt und in welcher Reihenfolge.

Repository: SvenKulessa/Finance

Stand: claude/pdf-dokumente-notebook-llm-l6kcxq @ 4eadf9d

Erzeugt am: 16.08.2026

Enthaltene Dokumente: 24

Umfang: ca. 16.909 Wörter

Dieses PDF ist eine Quelle für NotebookLM. Jedes eingebettete Dokument beginnt auf einer neuen Seite und nennt seinen Repository-Pfad, damit erzeugte Podcasts, Video-Skripte und Zusammenfassungen ihre Aussagen exakt auf die Originaldatei zurückführen können.

Inhalt dieses Quellpakets

1. CAPITAL-AI Konsolidierte Gesamtroadmap	4
docs/roadmaps/ROADMAP_CONSOLIDATION_MASTER_INDEX.md	
2. Core System & Infrastructure Backlog	8
docs/backlog/01-core-system.md	
3. Stripe Billing & User Access Backlog	9
docs/backlog/02-billing-stripe.md	
4. Compliance, Security & Data Privacy Backlog	10
docs/backlog/03-compliance-security.md	
5. Deactivated & Archived Modules Register	11
docs/backlog/04-deactivated-modules.md	
6. CAPITAL-AI Modular Backlog Architecture	12
docs/backlog/README.md	
7. server domain decomposition phase3 4 final 2	13
docs/coordination/claims/server-domain-decomposition-phase3-4-final-2.md	
8. Work claim — server domain decomposition phase 3.4	14
docs/coordination/claims/server-domain-decomposition-phase3-4-final.md	
9. Work claim — server domain decomposition phase 3.4	15
docs/coordination/claims/server-domain-decomposition-phase3-4.md	
10. AI Agent M0-M10 Implementation Roadmap	16
docs/roadmaps/AI_AGENT_M0_M9_IMPLEMENTATION_ROADMAP.md	
11. CAPITAL-AI — AI System Administration & Diagnostics IAM Roadmap	22
docs/roadmaps/AI_SYSTEM_ADMIN_DIAGNOSTICS_IAM_ROADMAP.md	
12. CAPITAL-AI DEVELOPMENT Chain Roadmap	27
docs/roadmaps/DEVELOPMENT_CHAIN_ROADMAP.md	
13. CAPITAL-AI Integrated Development Chain + Systemadmin Roadmap	41
docs/roadmaps/INTEGRATED_DEVELOPMENT_SYSTEMADMIN_ROADMAP.md	
14. M5A Systemadmin Repository Work Package	49
docs/roadmaps/M5A_SYSTEMADMIN_REPOSITORY_WORK_PACKAGE.md	
15. CAPITAL-AI Marketing Agent Roadmap	53
docs/roadmaps/MARKETING_AGENT_ROADMAP.md	
16. CAPITAL-AI S1 Security Hardening Roadmap	54
docs/roadmaps/S1_SECURITY_HARDENING_ROADMAP.md	
17. Screening · Scoring · Market Data — Single Point of Trust Roadmap	62
docs/roadmaps/SCREENING_SCORING_MARKET_DATA_SPT_ROADMAP.md	

18. CAPITAL-AI SEO + Google Marketing — Konsolidierte Programm-Roadmap	66
docs/roadmaps/SEO_GOOGLE_MARKETING_CONSOLIDATED_ROADMAP.md	
19. CAPITAL-AI Systemadmin Agent Roadmap	76
docs/roadmaps/SYSTEMADMIN_AGENT_ROADMAP.md	
20. Work Package SC-1 — Classification Consolidation	85
docs/roadmaps/work-packages/SC-1_CLASSIFICATION_CONSOLIDATION.md	
21. Work Package SC-3 — Unified DQ + Confidence Composite	87
docs/roadmaps/work-packages/SC-3_UNIFIED_DQ_CONFIDENCE.md	
22. Work Package SC-4 — Gateway Hardening & Provider Matrix	89
docs/roadmaps/work-packages/SC-4_GATEWAY_HARDENING_PROVIDER_MATRIX.md	
23. Work Package SC-5 — Live Coverage Expansion	91
docs/roadmaps/work-packages/SC-5_LIVE_COVERAGE_EXPANSION.md	
24. Work Package SC-7 — Ranking Composite Opt-In	93
docs/roadmaps/work-packages/SC-7_RANKING_COMPOSITE_OPT_IN.md	

CAPITAL-AI Konsolidierte Gesamtroadmap

Quelle: docs/roadmaps/ROADMAP_CONSOLIDATION_MASTER_INDEX.md

CAPITAL-AI Konsolidierte Gesamtroadmap

Status: ACTIVE — CANONICAL EXECUTION PORTFOLIO

Stand: 2026-08-15

Repository-Baseline: `main@0c07e1a43fde4dc0419f5f60ac74230608927393`

Owner: SvenKulesa

Authority: ADR-0071 + ESS-0023 + ROADMAP-INTEGRATED-DC-SA-0001

1. Zweck

Dieses Dokument ersetzt den bisherigen reinen Portfolio-Index durch eine vollständige, dokumentenbasierte Ausführungsroadmap. Es führt alle noch offenen Roadmaps, die DEVELOPMENT Chain M0-M10, die P0-P3-Prioritäten und begrenzte Systemadministrator-Prototypaufträge zusammen.

Es ersetzt keine restriktivere ADR-, ESS-, IAM-, REM-, Runbook-, Evidence- oder Human/Owner-Authority. Ein Status `DOCUMENTATION READY` oder `PROTOTYPE READY` erzeugt keine Mutationsberechtigung.

Domain-Update 2026-08-15: SEO Management und Marketing Agent sind in **SEO-GM-ROADMAP-0002** (`docs/roadmaps/SEO_GOOGLE_MARKETING_CONSOLIDATED_ROADMAP.md`) zu einem Single Point of Trust konsolidiert. Die früheren Dateien `docs/seo/SEO_MANAGEMENT_ROADMAP.md` und `docs/roadmaps/MARKETING_AGENT_ROADMAP.md` sind SUPERSEDED.

Integration 2026-08-15: Die DEVELOPMENT Chain und der Systemadmin-Agent sind in der kanonischen Ausführungsroadmap **ROADMAP-INTEGRATED-DC-SA-0001** (`docs/roadmaps/INTEGRATED_DEVELOPMENT_SYSTEMADMIN_ROADMAP.md`) verbunden. Diese Integrated Roadmap ist die verbindende Ausführungsautorität für DC + SA Phasen (I0-I4).

2. Verbindliche Authority-Reihenfolge

1. verifizierte Runtime-, Code- und Produktions-Evidence;
2. ausdrückliche Human/Owner-Freigabe;
3. spezifische ADR/ESS/IAM/REM/Runbook-Authority;
4. `INTEGRATED_DEVELOPMENT_SYSTEMADMIN_ROADMAP.md` (ROADMAP-INTEGRATED-DC-SA-0001) für DC+SA-Verbindung;
5. `DEVELOPMENT_CHAIN_ROADMAP.md` (Detail-Phasen);
6. diese Gesamtroadmap (Portfolio-Index);
7. Fachroadmaps (für SEO/Google Marketing: **SEO-GM-ROADMAP-0002**);
8. historische oder als Legacy/SUPERSEDED markierte Indizes.

Bei Widerspruch gilt die restriktivere, aktuellere und spezifischere Regel.

3. Konsolidiertes Portfolio

ID	Programm	Quelle	Konsolidierter Status	Nächster zulässiger Schritt
DC-SA	Integrated DC + SA	docs/roadmaps/INTEGRATED_DEVELOPMENT_SYSTEM_ADMINISTRATOR_ROADMAP.md (ROADMAP-INTEGRATED-DC-SA-0001)	ACTIVE — CANONICAL ; I0 VERIFIED PASS; I1 (M8) VERIFIED PASS (2026-08-16); I2 (M9) unblocked, not yet started	I2/M9-Vorbereitung nur auf separate, ausdrückliche Owner-Anweisung; einzelne Drills bleiben Owner-autorisiert
DC	DEVELOPMENT Chain	docs/roadmaps/DEVELOPMENT_CHAIN_ROADMAP.md	M0-M8 VERIFIED PASS (M8 2026-08-16); M9 unblocked, not yet started; M10 blockiert	M9-Drill-Vorbereitung nur auf separate, ausdrückliche Owner-Anweisung; jeder einzelne Drill separat autorisiert
S1	Security Hardening	docs/roadmaps/S1_SECURITY_HARDENING_ROADMAP.md	READY FOR OWNER REVIEW; S1.0-S1.6 nicht vollständig VERIFIED PASS	F-01-F-18 gegen aktuelles main revalidieren
DOC	Documentary/Event Value Chain	docs/architecture/DOCUMENTARY_EVENT_VALUE_CHAIN_ROADMAP.md	ACTIVE / PARTIAL	D0 read-only Baseline
SA	Systemadministrator-Agent	docs/roadmaps/SYSTEM_ADMINISTRATOR_AGENT_ROADMAP.md	SA0-SA4 VERIFIED PASS; SA5 blockiert	dokumentenbasierte Prototypen nach ESS-0023
IAM-DIAG	Diagnostics IAM	docs/roadmaps/AI_SYSTEM_DIAGNOSTICS_IAM_ROADMAP.md	teilweise überholt, nicht vollständig evidenzgebunden	retained/superseded/migrated-Matrix
SEO-GM	SEO + Google Marketing + Content Distribution	docs/roadmaps/SEO_GOOGLE_MARKETING_CONSOLIDATED_ROADMAP.md (SEO-GM-ROADMAP-0002)	ACTIVE — CANONICAL ; Q weitgehend DONE; S3 DONE; S1 IN PROGRESS; MA/Content DRAFT	WP-Q-CLOSE (Owner GSC), WP-M0 (ADR-0068/ESS-0022 Review), WP-D1-D3, S1 Persistenz
MA	Marketing Agent (historisch)	docs/roadmaps/MARKETING_AGENT_ROADMAP.md	SUPERSEDED → SEO-GM	keine parallele Fortschreibung
SEO	SEO Management (historisch)		SUPERSEDED → SEO-GM	keine parallele Fortschreibung

ID	Programm	Quelle	Konsolidierter Status	Nächster zulässiger Schritt
		docs/seo/SEO_MA-NAGE-MENT_ROADMAP.md		
GOV	GitHub/CI/Branch Governance	DEVELOPMENT Policy + PR-Template	laufend	Kosten-, Gate- und Branch-Cleanup-Evidence pflegen
AI-T	AI-Transparenz/Provenance	ADR-0057/0059/0062 + Documentary Provenance; eigener Content-Transparency-Contract noch offen	teilweise nachgewiesen	P0-Vertrag für kundenwirksame Ausgaben erstellen und Ausgabe-/Auditpfade verifizieren

Nicht als eigene offene Programme zählen: docs/architecture/ROADMAP.md , AI_AGENT_M0_M9_IMPLEMENTATION_ROADMAP.md , abgeschlossene Vocabulary-Migrationen, einzelne Work Packages und Work Claims.

Hinweis zur Nummerierung: Die vorhandene .ai/skills/ESS-0020-Supabase-Native-MFA-AAL2-Hardening.md ist ausschließlich MFA/AAL2-Authority. Sie darf nicht als AI-Content-Transparency-Contract zitiert werden. Ein eigener Transparenzvertrag bleibt Bestandteil von P0-1 und erhält erst nach Kollisionsprüfung eine freie ESS-ID.

4. Mutationsanfrage und Freigabe

Eine Mutation darf initiiert werden durch:

- den Owner im Chat, PR oder freigegebenen Mandat;
- den Systemadministrator-Agenten als formale Rückfrage mit Lösungsvorschlägen.

Eine Agentenanfrage ist keine Genehmigung. Vor jeder sicherheits-, datenintegritäts-, manipulations- oder produktionsrelevanten Mutation muss ein Mutation Proposal vorliegen (Felder unverändert wie zuvor dokumentiert).

Nur der Owner kann HIGH/CRITICAL-, Produktions-, IAM-, Billing-, Datenbank-, Deployment-, Secret-, DNS- oder externe Plattformmutation genehmigen. Provider- oder Modellidentität erzeugt keine Authority.

5-13. DEVELOPMENT Chain, Prioritäten, Prototyp-Vertrag, Abhängigkeiten

Der Inhalt der Abschnitte 5-13 aus dem Stand 2026-08-14 bleibt in Substanz gültig (M5/M5A/M6/M7 Evidence, P0-P3, SA-Prototypen, Branch-Lifecycle).

Anpassung P3-2: SEO/Marketing-Baseline ist nicht mehr „parallel read-only Q1-Q6/MA0“, sondern folgt **SEO-GM-ROADMAP-0002** (Single Point of Trust). SA-P11 bleibt read-only Revalidator gegen die neue kanonische Roadmap, ohne Publikation.

Ausführungsbacklog Position 11: „SEO/MA/Monetarisierung“ → Ausführung ausschließlich unter SEO-GM-ROADMAP-0002 und jeweiliger ADR/ESS-Authority.

Abschlusskriterien (unverändert im Kern)

Die Roadmap ist erst abgeschlossen, wenn M0-M10 VERIFIED PASS, P0/P1 geschlossen oder akzeptiert, keine unowned HIGH/CRITICAL, produktive Mutationen Owner-genehmigt, Traceability vollständig, **offene Fachroadmaps abgeschlossen, superseded oder archiviert** (SEO+MA: durch SEO-GM-ROADMAP-0002 erfüllt sobald dessen DoD erreicht ist), und alle gemergten Arbeitsbranches gelöscht sind.

* Core System & Infrastructure Backlog

Quelle: docs/backlog/01-core-system.md

□

Core System & Infrastructure Backlog

Track core engine improvements, model router latencies, and server-side configurations.

Open Items

1. Model Router Latency Checks

- **Description:** Ensure the auto-routing layer selects model endpoints with response latencies under 200ms.
- **Priority:** High
- **Status:** Completed (Active telemetry monitoring visible in Orchestrator Panel).

2. Multi-Agent Memory Refinement

- **Description:** Standardize session context caching for parallel commodity classification requests.
- **Priority:** Medium
- **Status:** Planned

3. ADR numbering CI uniqueness gate (AUD5-F-002)

- **Description:** No CI step prevents duplicate `ADR-NNNN` filename numbers across `docs/adr/`; the same collision has now recurred three times (most recently `ADR-0028`). See `docs/architecture/ENTERPRISE_FINTECH_SCREENING_GOVERNANCE_AUDIT.md` Kapitel 5/10.1 (AUD5-F-002, Q2).
- **Priority:** High
- **Status:** Open

4. Production bundle code-splitting (D3)

- **Description:** `vite.config.ts` has no `manualChunks / chunkSizeWarningLimit`; production build still emits a single ~2.48 MB JS chunk. Carried across two audit cycles now — see `docs/architecture/ENTERPRISE_FINTECH_SCREENING_GOVERNANCE_AUDIT.md` Kapitel 10.2 (D3).
- **Priority:** Medium
- **Status:** Open

Stripe Billing & User Access Backlog

Quelle: docs/backlog/02-billing-stripe.md

Stripe Billing & User Access Backlog

Track enterprise pricing models, subscription tiers, and user verification workflows.

Open Items

1. Enterprise Billing Layer refactor

- **Description:** Exclusively map user payments and billing portals to the Supabase Auth User ID instead of user email.
- **Priority:** Critical
- **Status:** Active (Tracking database-side integration requirements).

2. Credit-Based Consumption Plan

- **Description:** Enable micro-credits for expensive Multi-Agent commodity classification actions.
- **Priority:** Medium
- **Status:** Draft

Compliance, Security & Data Privacy Backlog

Quelle: docs/backlog/03-compliance-security.md

0

Compliance, Security & Data Privacy Backlog

Track security updates, audits, and compliance regulations.

Open Items

1. PII Masking on Diagnostic Logs

- **Description:** Automatically mask user emails, full IP addresses, and authentication tokens before printing server-side diagnostics.
- **Priority:** High
- **Status:** Completed (Active regex filtering applied to telemetry outputs).

2. DSGVO / GDPR Portability Archiver

- **Description:** Permit users to download a standard JSON archive of their logs and portfolio backtests.
- **Priority:** Medium
- **Status:** Completed

3. Persistent fabricated audit-trail write in `AuditLogs.tsx` (AUD5-F-001)

- **Description:** `src/components/AuditLogs.tsx:215-216` still writes `Math.random()`-generated `dataQualityScore / finalScore` to a persistent file via `server/orchestrator.ts:114-163`, indistinguishable from a real audit record after being written. See `docs/architecture/ENTERPRISE_FINTECH_SCREENING_GOVERNANCE_AUDIT.md` Kapitel 5 (AUD5-F-001) for full detail — this is the second consecutive audit naming it unfixed.
- **Priority:** Critical
- **Status:** Open

Deactivated & Archived Modules Register

Quelle: docs/backlog/04-deactivated-modules.md

Deactivated & Archived Modules Register

Keep track of deactivated/archived features for subsequent reactivation phases.

Deactivated Elements

1. Value-at-Risk (VaR) Risiko-Assessment

- **Component:** `RealTimeRiskAssessment.tsx`
- **Description:** Historical and Monte-Carlo Value-at-Risk simulation workbench.
- **Status:** Archived (Deactivated per user instructions, code preserved as inactive asset).

2. Quantum Interact Workspace (Modul 2)

- **Component:** `InteractModule.tsx`
- **Description:** Real-time collaborative agent-to-agent workspace.
- **Status:** Archived (Deactivated per user instructions, code preserved as inactive asset).

CAPITAL-AI Modular Backlog Architecture

Quelle: docs/backlog/README.md

CAPITAL-AI Modular Backlog Architecture

Welcome to the new modular backlog architecture for the CAPITAL-AI platform. By splitting the backlog into domain-specific registries, we prevent metadata noise and align future developmental sprints with high compliance, modular engineering, and production standards.

Backlog Directory Structure

The backlog is organized into the following specialized registers:

1. **01-core-system.md** : Core system upgrades, model auto-router optimization, and telemetry logging improvements.
2. **02-billing-stripe.md** : Transition to Stripe Customer-ID & Supabase Auth UUID-based enterprise billing layer (removing Email-based identification completely).
3. **03-compliance-security.md** : DSGVO/GDPR export pipelines, PII masking, and multi-agent regulatory compliance tracking.
4. **04-deactivated-modules.md** : Specs and restoration guidelines for deactivated modules (e.g., VaR Risiko-Assessment, Quantum Interact Workspace).

Active Milestone: Version 0.6.5 (Production & Enterprise Hardening)

- All development tracks adhere strictly to the **Version 0.5.5 / 0.6.0** milestones.
- Strictly enforcing single-point security loops and isolated server modules.

Referenced Audit: ARCH-AUDIT-0005

See `docs/architecture/ENTERPRISE_FINTECH_SCREENING_GOVERNANCE_AUDIT.md` for the current full status report and prioritized roadmap. One P0 remains open across two audit cycles (AUD5-F-001, `src/components/AuditLogs.tsx:215-216`) — see `03-compliance-security.md`.

server domain decomposition phase3 4 final 2

Quelle: docs/coordination/claims/server-domain-decomposition-phase3-4-final-2.md

Phase 3.4 remains additive. Shared compatibility and roadmap-critical runtime paths are intentionally not modified in this PR.

Work claim — server domain decomposition phase 3.4

Quelle: docs/coordination/claims/server-domain-decomposition-phase3-4-final.md

Work claim — server domain decomposition phase 3.4

Status: active Base: main @ 2ffc307a0405a872665718c244c9cd990a69549a

Exclusive scope: provider-facing market-data adapter extraction and its contract tests/docs.

Protected paths in this PR: `server.application.ts`, `server/validateRuntimeSecrets.ts`, `server/stripe.ts`, `server/runtime/**`, `Dockerfile`, `render.yaml`, and scoring services.

Work claim — server domain decomposition phase 3.4

Quelle: docs/coordination/claims/server-domain-decomposition-phase3-4.md

Work claim — server domain decomposition phase 3.4

Status: active Owner: ChatGPT architecture workstream Base: main @ 2ffc307a0405a872665718c244c9cd990a69549a

Exclusive scope: - `server/routes/alphaVantageRoutes.ts` - market-data adapter extraction documents/tests created by this workstream

Protected / do not modify in this PR: - `server.application.ts` - `server/validateRuntimeSecrets.ts` - `server/stripe.ts` - `server/runtime/**` - `Dockerfile` - `render.yaml` - `src/services/*Scoring*` - R-001/R-002/R-003 governance artifacts

Purpose: prepare provider-facing HTTP adapters before a separately gated shared-file cutover.

AI Agent M0-M10 Implementation Roadmap

Quelle: docs/roadmaps/AI_AGENT_M0_M9_IMPLEMENTATION_ROADMAP.md

AI Agent M0-M10 Implementation Roadmap

Legacy filename retained for stable references. Canonical operational phase index:

docs/roadmaps/DEVELOPMENT_CHAIN_ROADMAP.md .

Status: IMPLEMENTATION PHASE Status date: 2026-08-12 Baseline:

main@91963f59b74c8c3c3c0b33c6a23237a01ac0128e (PR #222 merge) Platform version: 0.6.0

Global execution rule

Every required DEVELOPMENT Chain mutation follows:

```
ROADMAP / ESS / ADR / RUNBOOK
→ HUMAN APPROVAL
→ PRE-MUTATION VERIFICATION
→ MUTATION
→ POST-MUTATION VERIFICATION
→ EVIDENCE
→ ROADMAP / TRACEABILITY UPDATE
→ NEXT PHASE
```

No later phase starts while a required predecessor mutation/test is missing, failed, inconclusive or undocumented.

Cross-cutting authorities:

- docs/governance/DEVELOPMENT_CHAIN_EXECUTION_POLICY.md
- docs/governance/DEVELOPMENT_CHAIN_BRANCH_LIFECYCLE_POLICY.md
- docs/governance/DEVELOPMENT_CHAIN_RESPONSIBILITY_MATRIX.md
- docs/contracts/DEVELOPMENT_CHAIN_MUTATION_HANDOFF_CONTRACT.md
- .ai/contracts/development-chain-mutation-handoff.schema.json
- docs/runbooks/DEVELOPMENT_CHAIN_PHASE_EXECUTION.md

A Mutation Handoff is non-authorizing. Human/Owner approval, REM/IAM/reserved-action policy, verified Execution Host and durable audit remain separate gates.

Current Systemadmin execution-host state

PR #220 merged the SA3B GitHub-Actions/OIDC Execution-Host repository implementation.

The first real post-merge host probe reached the broker and proved fail-closed: strict request/REM/OIDC checks passed, durable M5 persistence failed, and the requested branch side effect was skipped.

Diagnosis found:

- application writer↔production M5 schema vocabulary drift;
- separate privileged Supabase backend credential failure (`Unregistered API key`).

PR #222 corrected the writer↔schema contract and regression coverage and merged at `main@91963f59b74c8c3c3c0b33c6a23237a01ac0128e` .

SA3B is still **VERIFICATION PENDING** until a valid Owner-controlled privileged Supabase backend credential is available, a real positive `BRANCH_PROBE` proves Authorization Evidence before the side effect and SUCCESS Outcome Evidence after it, a no-permit/stale negative probe produces no side effect, and the probe branch is deleted.

Until then, DEVELOPMENT Chain does not classify that host as a generally verified autonomous mutation executor.

Human/Owner CI rule

Transitional until M10 VERIFIED PASS

FILES CHANGED → VIEWED → CURRENT-HEAD REVIEW (`/okay`) → OWNER CHECKBOXES LAST → ONE build-and-test

New commits invalidate current-head review evidence. CI does not authorize merge.

M10 target after controlled cutover

FILES CHANGED / VIEWED
→ exact PR-state resolution
→ WebAuthn/passkey Owner assertion
→ immutable approval evidence
→ exactly one CI consumption
→ build-and-test
→ Human merge

After cutover, emoji/text reviews and Owner checkboxes no longer authorize CI.

Repository lifecycle

Every work item uses a fresh branch from then-current `main` . After successful Human merge, the Finance remote branch is deleted and never reused. Ephemeral clones/worktrees created only for the work item are removed after required Evidence is secured.

Phase summary

Phase	Status	Key gate
M0 Evidence Baseline	COMPLETE	preserve read-only evidence
M1 Git Guardrails	COMPLETE	Human merge + protected main
M2/M2G Architecture + Freeze	COMPLETE	sequential implementation only
M3 CI Hardening	COMPLETE	one bounded expensive CI path

Phase	Status	Key gate
M4 Agent IAM	COMPLETE	negative IAM / no autonomous MERGE
M5 Audit	VERIFIED PASS	PR #222 corrected mapping; real privileged audit insert confirmed 2026-08-14, see <code>docs/evidence/m5/M5_VERIFIED_PASS_CLOSURE_EVIDENCE.md</code>
M5A Native MFA/AAL2	IN PROGRESS	code/CI then separate Owner production approval and native AAL2 verification
M6 Supply Chain	BLOCKED BY M5A	source→SBOM→artifact→provenance/attestation verified
M7 Deployment Identity	BLOCKED BY M6	exact approved platform mutation + postverify/rollback
M8 Agent Cutover	BLOCKED BY M7	provider-neutral policy equivalence + no bypass
M9 Assurance	BLOCKED BY M8	injection/replay/exfiltration/audit/kill-switch/break-glass/rollback drills
M10 Passkey-only Owner CI Auth	BLOCKED BY M9	exact-state WebAuthn + shadow/recovery/replay + legacy cleanup

M5A — Supabase Native TOTP MFA / AAL2 Hardening

Authorities:

- ESS-0020;
- ADR-0064;
- ADR-0003.5;
- `docs/evidence/m5a/M5A_SUPABASE_TOTP_AAL2_BASELINE.md` ;
- `docs/runbooks/M5A_SUPABASE_TOTP_AAL2_HARDENING.md` .

Recorded baseline proves the historical CAPITAL-AI custom TOTP mechanism is distinct from Supabase Native MFA/AAL2. Native factor/AAL2 enforcement still requires implementation and controlled Owner enrollment.

Required sequence:

1. fresh implementation branch from current `main` ;
2. Native TOTP `enroll` → `challenge` → `verify` ;
3. centralized server AAL2 verification;
4. privileged AAL1 and Auth/factor lookup errors fail closed;
5. purpose-bound app step-up remains defense-in-depth only;
6. recovery/factor reset redesign;

7. positive/negative tests;
8. repository CI `VERIFIED PASS` ;
9. read-only production precheck;
10. separate explicit Human/Owner mutation approval;
11. Owner native factor enrollment one identity at a time;
12. AAL2/recovery/advisor verification;
13. Evidence + Roadmap synchronization.

Mutation classification:

- repository code: `REQUIRED / PLANNED` ;
- Owner Native TOTP enrollment: `REQUIRED / NOT YET AUTHORIZED` at baseline;
- Supabase Auth project config: `CONDITIONAL` only if exact need is proven;
- new Native MFA Postgres DDL: `NOT REQUIRED` ;
- legacy custom-TOTP cleanup: `DEFERRED / SEPARATE APPROVAL` ;
- Stripe/Render: `NOT REQUIRED` for M5A.

M6 remains blocked until M5A `VERIFIED PASS` .

M6 — Supply Chain Provenance & Attestation

BLOCKED — DOCUMENTATION READY.

Authority/runbook:

- ADR-0060;
- `docs/architecture/ai-agent/AI_AGENT_SUPPLY_CHAIN_MODEL.md` ;
- `docs/runbooks/M6_SUPPLY_CHAIN_PROVENANCE.md` .

Required chain:

```
source SHA → lockfile digest → SBOM → tests/build → artifact digest → provenance → attestation → deployment/runtime identity
```

External platform mutation is `NOT REQUIRED` by default for M6.

M7 — Deployment Identity + Platform Mutation Gate

BLOCKED — DOCUMENTATION READY.

Authority/runbook:

- ADR-0061;
- `docs/architecture/ai-agent/AI_AGENT_DEPLOYMENT_IDENTITY.md` ;
- `docs/runbooks/M7_DEPLOYMENT_IDENTITY_MUTATION.md` .

Every external mutation requires exact target, precheck, separate Owner mutation approval, non-authorizing Handoff, audited authorized execution, post-verification and rollback.

Stripe/Supabase are included only when explicitly named by dedicated Authority. DNS/TLS/IONOS remains Human-reserved absent a later stronger ADR.

M8 — Provider-neutral Agent Cutover

BLOCKED — DOCUMENTATION READY.

Authority/runbook:

- ADR-0062;
- ESS-0019;
- Provider Profile Contract;
- `docs/runbooks/M8_AGENT_CUTOVER.md` .

ChatGPT, Claude, Google AI Studio and future transports obey the same semantic capability policy. Read-only research profiles fail mutation tests. Provider/model identity cannot elevate authority.

M9 — Assurance / Incident / Break-Glass

BLOCKED — DOCUMENTATION READY.

Authority/runbook:

- ADR-0063;
- `docs/architecture/ai-agent/AI_AGENT_INCIDENT_RESPONSE.md` ;
- `docs/runbooks/M9_ASSURANCE_INCIDENT_BREAK_GLASS.md` .

Mandatory assurance includes authorization bypass, prompt/tool injection, replay/idempotency, secret/data exfiltration, audit outage/completeness, kill switch, break-glass, rollback/recovery and independent Evidence review.

M10 — Passkey-only Human/Owner PR Authorization

BLOCKED — COMPLETE PLANNING PACKAGE PREPARED.

Authorities:

- ADR-0066;
- `.ai/skills/ESS-0022-Passkey-Only-Owner-PR-Authorization.md` ;
- `docs/architecture/ai-agent/M10_PASSKEY_OWNER_PR_AUTHORIZATION_THREAT_MODEL.md` ;
- `docs/runbooks/M10_PASSKEY_OWNER_PR_AUTHORIZATION.md` .

Every approval binds Owner, Finance repository, PR, exact base/head SHA, canonical changed-file-set hash, diff/review digest, `AUTHORIZE_PR_CI` , challenge freshness and consumption state.

Human file review and Human-only merge remain mandatory.

Mutation Executor integration

The `capital-ai-systemadmin-roadmap-executor` becomes a bounded DEVELOPMENT Chain mutation executor only after its actual execution-host exit gate is independently `VERIFIED PASS`.

Handoff artifacts:

- `docs/contracts/DEVELOPMENT_CHAIN_MUTATION_HANDOFF_CONTRACT.md` ;
- `.ai/contracts/development-chain-mutation-handoff.schema.json` .

A Handoff cannot expand REM/capabilities, bypass Human approval or authorize `MERGE` .

Mandatory per-step synchronization

Every completed work item updates:

1. `docs/architecture/ROADMAP.md` ;
2. `docs/roadmaps/DEVELOPMENT_CHAIN_ROADMAP.md` ;
3. this legacy implementation roadmap;
4. `docs/traceability/AI_AGENT_M0_M9_TRACEABILITY_MATRIX.md` ;
5. `docs/traceability/DEVELOPMENT_CHAIN_DOCUMENT_TRACEABILITY_MATRIX.md` ;
6. affected ADR/ESS;
7. Evidence and mutation state;
8. branch deletion state;
9. explicit next gate.

Current next gate

M5A repository remediation is the next executable DEVELOPMENT Chain step.

Parallel dazu muss die PR-#222-Korrektur produktiv verifiziert und SA3B positiv/negativ abgeschlossen werden, bevor der autonome Mutation Executor für spätere externe Mutationen als `VERIFIED PASS` gilt. M6-M10 planning completeness does not authorize their implementation or mutation.

CAPITAL-AI — AI System Administration & Diagnostics IAM Roadmap

Quelle: docs/roadmaps/AI_SYSTEM_ADMIN_DIAGNOSTICS_IAM_ROADMAP.md

CAPITAL-AI — AI System Administration & Diagnostics IAM Roadmap

Date: 2026-08-10 Scope: GitHub, Render, Supabase, Stripe, application runtime, market-data providers and AI orchestration.

Mission

Enable AI-assisted system administration and diagnosis while preserving least privilege, human-controlled critical mutations, evidence-first operations and strict separation between observation, diagnosis and production mutation.

Target operating model

Tier A — Observer

Capabilities: - read deployment state, health, logs and metrics; - read Supabase schema metadata, migrations and advisors; - read GitHub code, PRs, CI and release evidence; - read Stripe catalog/webhook configuration metadata; - generate diagnostic reports and incident timelines.

Credential model: - read-only connector/service identity; - no raw production secret exposure; - no DDL/DML mutation rights.

Tier B — Diagnostic Operator

Capabilities: - execute bounded read-only SQL; - correlate request IDs, deploy IDs, Stripe event IDs and audit IDs; - run health probes, integrity checks and controlled read-only test queries; - classify incidents and produce remediation plans; - create GitHub issues/PRs containing remediation code and migrations.

Credential model: - purpose-specific diagnostics service account; - RLS-/read-only database role where feasible; - repository write permission only for isolated branches/PRs.

Tier C — Operations Agent

Capabilities: - controlled redeploy/restart; - retry idempotent jobs/events; - update bounded non-secret configuration; - pause/resume approved workers; - perform reversible cache/queue maintenance.

Controls: - IAM capability check; - mutation intent + reason; - idempotency key; - pre/post health evidence; - automatic rollback trigger where possible.

Tier D — Privileged Administrator

Capabilities: - apply reviewed database migrations; - rotate service credentials; - change RLS/grants/functions; - modify production secrets/environment variables; - change webhook and provider security configuration.

Controls: - owner/admin role; - step-up TOTP/passkey; - explicit production-change authorization; - dual evidence: precondition + postcondition; - mandatory audit record; - rollback/runbook reference.

Tier E — Break Glass

Capabilities: - emergency privileged recovery only.

Controls: - disabled by default; - owner activation; - short TTL; - reason and incident ID mandatory; - narrowest possible capability set; - session/token revocation at expiry; - mandatory post-incident review.

Service-account/key architecture

Identity	Intended use	Default rights	Mutation rights
capital-ai-diagnos-tics	health, logs, reports	read-only	none
capital-ai-web-run-time	application requests	application-scoped	only approved runtime RPCs
capital-ai-billing-processor	Stripe event processing	billing tables/RPCs	idempotent billing side effects
capital-ai-ci-release	CI/release evidence	repo/build	reviewed deployment workflow only
capital-ai-db-migrator	schema migration	schema-admin during job	DDL only in approved migration window
capital-ai-security-auditor	IAM/RLS/advisor review	read-only security meta-data	none
capital-ai-break-glass	incident recovery	disabled	temporary explicit grant

Modern Supabase key contract: - client/public: `sb_publishable_*` only; - server privileged API client: `sb_secret_*` only; - do not use publishable credentials as privileged fallback; - legacy `anon` / `service_role` removed only after consumer inventory and cutover evidence.

Roadmap

Phase 0 — Credential inventory and containment (P0)

- inventory every consumer of Supabase/Stripe/Render/GitHub credentials;
- classify each credential as public, service, admin or break-glass;
- prohibit secret values in logs, PRs and diagnostic reports;

- set modern Supabase publishable key contract;
- provision/store `SUPABASE_SECRET_KEY` using `sb_secret_*`;
- maintain legacy keys only as temporary rollback compatibility.

DoD: every credential has owner, scope, storage location, consumers and rotation procedure.

Phase 1 — Diagnostic plane (P0/P1)

Build a read-only diagnostic control plane capable of: - `/healthz` and deploy identity validation; - Render CPU/memory/request/latency checks; - Supabase migration drift, RLS/advisor and connection checks; - Stripe webhook/event/catalog consistency checks; - GitHub main/PR/CI/deploy drift checks; - provider health and freshness checks; - cross-system incident report generation.

DoD: an AI diagnostic agent can explain platform state without mutation credentials.

Phase 2 — Mutation gateway (P1)

Introduce one policy-enforced mutation gateway/contract rather than direct arbitrary tool use.

Required mutation envelope: - `operation_id` / idempotency key; - principal/service identity; - target; - action/capability; - reason/work item; - requested parameters with secret redaction; - precondition evidence hash; - approval/step-up claim when required; - execution timestamp; - result; - rollback action; - postcondition evidence.

DoD: every production mutation is attributable and replay-safe where meaningful.

Phase 3 — Database administration roles (P1)

- create/read-only diagnostics DB role or equivalent constrained service path;
- isolate migration execution under `capital-ai-db-migrator`;
- remove generic service-secret use from diagnostic tooling;
- constrain application runtime writes to explicit tables/RPCs;
- review SECURITY DEFINER functions, EXECUTE grants and search_path;
- centralize migration drift/evidence reporting.

DoD: diagnostics cannot accidentally execute DDL/DML; migrator cannot act as web runtime.

Phase 4 — Platform operations capabilities (P1/P2)

Capability catalogue examples: - `render.deploy.read` - `render.deploy.trigger` - `render.logs.read` - `supabase.schema.read` - `supabase.sql.read` - `supabase.migration.apply` - `supabase.auth.config.write` - `supabase.secret.rotate` - `stripe.events.read` - `stripe.webhook.write` - `github.repo.read` - `github.pr.write` - `github.merge.request`

Map each capability to IAM role, service identity, required step-up and audit severity.

Phase 5 — Automated diagnostics and evidence reports (P2)

- scheduled platform integrity report;
- deployment drift report;
- database/security advisor report;
- billing/webhook integrity report;
- market-data freshness/provider report;
- IAM privilege drift report;
- secret/key age and rotation-due report.

Reports MUST redact secrets and provide evidence references, not credential material.

Phase 6 — Controlled self-healing (P2/P3)

Permit only pre-approved low-risk actions automatically: - retry idempotent jobs; - restart unhealthy worker; - redeploy same known-good commit; - quarantine a failed provider and switch to an approved fallback; - disable a non-critical failing scheduled task.

Schema changes, secret rotation, billing mutations, IAM grants and destructive actions remain human-authorized.

Phase 7 — Break-glass and incident command (P2)

- TTL-based emergency elevation;
- incident commander role;
- scoped emergency capability grants;
- immutable incident audit trail;
- automatic credential/session revocation;
- post-incident evidence package and remediation PR.

Audit severity

- `READ` : diagnostic read, normal retention.
- `CHANGE_LOW` : reversible operational mutation.
- `CHANGE_HIGH` : configuration/security/billing mutation; step-up required.
- `PRIVILEGED` : schema/IAM/secret mutation; owner authorization required.
- `BREAK_GLASS` : emergency; highest retention and mandatory review.

Immediate execution order

1. Complete Supabase modern key cutover (`sb_publishable_*` , then `sb_secret_*`).
2. Verify web/runtime/CI consumers and remove legacy fallback only after evidence.
3. Close the outstanding R-003 Supabase migration drift.
4. Implement R-004 transactional PDF credit ledger.
5. Introduce diagnostic service identity and read-only capability catalogue.

6. Introduce mutation gateway + audit envelope.
7. Split web-runtime, billing, migrator and diagnostics privileges.
8. Add scheduled integrity/security/credential-age reports.
9. Add controlled self-healing for low-risk idempotent operations.
10. Formalize break-glass TTL and incident review.

Non-negotiable invariants

- No raw secret in model context when a connector can hold it.
- No VITE/client exposure of `sb_secret_*`.
- No privilege downgrade from secret to publishable key.
- No production mutation without attributable identity and evidence.
- No autonomous destructive mutation.
- No billing/IAM/schema mutation without explicit policy authorization.
- Every critical mutation has rollback and postcondition validation.

CAPITAL-AI DEVELOPMENT Chain Roadmap

Quelle: docs/roadmaps/DEVELOPMENT_CHAIN_ROADMAP.md

CAPITAL-AI DEVELOPMENT Chain Roadmap

Status: IMPLEMENTATION ROADMAP Status date: 2026-08-14 Current repository baseline:

`main@0efeb05e507698129ff1d72de4887554d3f32100` (PR #256 merge) Repository: `SvenKullessa/Finance` Platform version: `0.6.0`

Sync 2026-08-14 (nach PR #255 Merge): M5A-Repository-Code ist gemerged; `main` erzwingt seither serverseitig eine echte AAL2-Sitzung für Step-Up-Ausstellung (`requireVerifiedAal2`). PR #256 (offen, Direktauftrag außerhalb dieser Roadmap-Kette, gleiche Session) ergänzt zusätzlich: Löschung der `break_glass_codes` -Produktionsdaten, DSGVO-Consent-Log + Land/Telefon bei Registrierung, verpflichtendes Onboarding (mind. 1 Faktor) für neue Konten, Schutz gegen Entfernen des letzten Faktors bei verpflichteten Konten, sowie Stripe-SEPA-Ausschluss bei neuen Abos. Keine dieser Ergänzungen ändert den M5A-Phasenstatus unten — sie sind Owner-Direktaufträge, keine Roadmap-Phasenausführung.

Rolle dieses Dokuments

Dieses Dokument ist der operative Phasenindex der DEVELOPMENT Chain. Historische Details bleiben in `docs/architecture/ROADMAP.md`, den ADRs, ESS-Dateien und Evidence-Dokumenten erhalten.

Es ersetzt keine bestehende Authority. Bei Widerspruch gilt die restriktivere Regel aus Roadmap, ADR, ESS, Human/Owner Policy, Agent IAM, REM oder plattformspezifischem Runbook.

Kanonische Ausführungsregel

```
READ-ONLY BASELINE
→ ROADMAP / GAP / ESS / ADR / RUNBOOK
→ HUMAN/OWNER REVIEW
→ FRESH BRANCH FROM CURRENT MAIN
→ REPOSITORY IMPLEMENTATION
→ PR / HUMAN FILE REVIEW / CI
→ HUMAN MERGE
→ BRANCH DELETE
→ OPTIONAL EXTERNAL PRECHECK
→ EXPLICIT OWNER MUTATION APPROVAL
→ NON-AUTHORIZING MUTATION HANDOFF
→ AUTHORIZED EXECUTION HOST
→ POST-VERIFICATION
→ APPEND-ONLY EVIDENCE
→ ROADMAP / TRACEABILITY SYNC
→ NEXT PHASE
```

Authority: `docs/governance/DEVELOPMENT_CHAIN_EXECUTION_POLICY.md`.

Parallel Systemadmin / Mutation-Agent Workstream

Die Systemadmin-Authority ist gegenüber der älteren DEVELOPMENT-CHAIN-Baseline fortgeschritten:

- SA3B Execution Host: **COMPLETE / VERIFIED PASS**; am 2026-08-14 auf explizite Owner-Anweisung reaktiviert (`.github/workflows/systemadmin-roadmap-executor.yml` , `false` && -Sperrung entfernt), nutzt weiterhin exakt das bestehende `OWNER_APPROVED` -Mandat `.ai/mandates/REM-SA3B-PROBE-001.json` (gültig bis 2026-08-19), auditiertes Verzeichnis bleibt inhaltlich unverändert nachweisbar (`tests/unit/systemadminExecutionHostWorkflow.test.ts`);
- SA4 bounded autonomous repository work package: **COMPLETE / VERIFIED PASS**; Job nach Abschluss per `false` && -Bedingung stillgelegt (`.github/workflows/systemadmin-sa4-pilot.yml`), zusätzlich durch sein eigenes bereits gemergtes Zielartefakt dauerhaft self-blocking, auditiertes Verzeichnis bleibt inhaltlich unverändert nachweisbar (`tests/unit/systemadminSa4Contracts.test.ts`);
- permit-before-side-effect, positive/negative Host-Probes, M5 authorization/outcome evidence und Branch-Cleanup sind in der SA-Roadmap und Traceability dokumentiert;
- direkte ChatGPT→GitHub-Connector-Schreibvorgänge bleiben außerhalb des autonomen SA-Nachweispfades;
- SA5 externe Produktionsmutation bleibt bis M10 `VERIFIED PASS` blockiert.

Korrektur 2026-08-14 (Sicherheitsaudit): Der SA4-Pfad ist strukturell ein Ein-Zweck-Ein-Pfad-Host für genau `docs/evidence/sa4/SA4_FIRST_AUTONOMOUS_WORK_PACKAGE.md` unter `REM-SA4-PILOT-001` — sowohl `server/systemadmin/githubActionsOidc.ts` (Workflow-Ref-Allowlist) als auch `systemadminExecutionBrokerRouter.ts` (Mandats-Mapping) als auch `runSa4Pilot.mjs` (harte Mandats-/Pfad-Gleichheitsprüfung) verweigern jede andere Mandats-Bindung. Der verifizierte SA4-Pfad kann `REM-M5A-REPOSITORY-001` **nicht** ausführen. Details: `docs/evidence/security/SECURITY_AUDIT_2026-08-14_ADR0069_DEVELOPMENT_CHAIN.md` (Befund P1-2).

Owner-Entscheidung 2026-08-14: statt eines neuen SA-Ausführungshosts implementiert die Owner-instruierte Claude-Code-Sitzung das M5A-Repository-Code-Paket direkt im normalen Branch → PR → Human-Review → CI → Merge-Zyklus (kein neuer autonomer Host, kein `REM-M5A-REPOSITORY-001` -Statuswechsel auf `OWNER_APPROVED` nötig). Details/Evidence: `docs/evidence/m5a/M5A_REPOSITORY_IMPLEMENTATION_EVIDENCE.md` .

Für M5A gilt vorbehaltlich dieser Korrektur weiterhin die inhaltliche Begrenzung auf ein begrenztes Repository-Work-Package:

- Authority: `docs/roadmaps/M5A_SYSTEMADMIN_REPOSITORY_WORK_PACKAGE.md` ;
- Mandat: `.ai/mandates/REM-M5A-REPOSITORY-001.json` ;
- Mandatstatus bei Erstellung: `DRAFT` , damit kein Dokument seine eigene Autorität erzeugt;
- zulässig: Analyse, Branch, begrenzte Code-/Teständerungen, Commit, Draft-PR, CI-Request und redigierte Evidence;

- verboten: Supabase-Faktor-/Auth-Mutation, Secrets, Render/Stripe/IONOS, Rulesets, Merge, Owner-MFA/Break-Glass und Self-Expansion.

Aktivierung erfordert nach Merge eine exakte current-main-Bindung, Human/Owner-Akzeptanz von ESS-0020/ADR-0064, einen eigenen M5A-Ausführungshost gemäß obiger Korrektur sowie einen separaten `OWNER_APPROVED` -Status mit Approval-Evidence. Produktion bleibt bis zum späteren M5A-Mutation-Gate unberührt.

Phasenstatus

Phase	Execution State	Documentation Readiness	Authority	Mutation / Test Gate	Next Gate
M0 Evidence Baseline	COMPLETE	COMPLETE	<code>docs/evidence/m0/*</code>	read-only	preserve
M1 Git Guardrails	COMPLETE	COMPLETE	Owner/GitHub governance	policy validation	preserve
M2 Architecture / Documentation	COMPLETE	COMPLETE	ESS-0019 + ADR-0057..0063	documentation only	synchronized
M2G Documentation Freeze	COMPLETE	COMPLETE	Freeze policy	docs consistency	sequential implementation
M3 CI Hardening	COMPLETE	COMPLETE	ADR-0053/0060 + CI governance	scope-aware CI / Owner gate	preserve until M10 cutover
M4 Agent IAM	COMPLETE	COMPLETE	ADR-0058 + ESS-0018/0019	negative IAM tests	preserve
M5 Audit / Telemetry	VERIFIED PASS	COMPLETE	ADR-0056/0059 + M5 Evidence	PR #222 corrected writer deployed and confirmed via real successful privileged audit insert (<code>docs/evidence/m5/M5_VERIFIED_PASS_CLOSURE_EVIDENCE.md</code> , cross-verified against PR #229)	autonomous mutation remains blocked independent of this (SA5/M10 gate)
M5A Native MFA / AAL2	VERIFIED PASS	baseline + runbook + closure evidence complete	ESS-0020 + ADR-0064 + ADR-0003.5	repo code merged (PR #255/ #256) → beide Owner-Profile mit verifiziertem nativen TOTP-Faktor + bestätigter <code>aal2</code> -Sitzung (<code>docs/evidence/m5a/M5A_VERI-</code>	M6 unblocked

Phase	Execution State	Documentation Readiness	Authority	Mutation / Test Gate	Next Gate
				FIED_PASS_CLOSURE_EVIDENCE.md) → Advisor ohne unowned HIGH/CRITICAL	
M6 Supply Chain Provenance	VERIFIED PASS	RUNBOOK READY + repo evidence	ADR-0060	source→lockfile→SBOM→provenance chain implemented, merged, and confirmed on the real hosted push -to- main build path: run 31834114193 signed the provenance statement via cosign keyless signing (Sigstore Fulcio/Rekor) and verified it in the same run (co-sign verify-blob ... Verified OK) against the exact expected certificate identity and OIDC issuer (docs/evidence/m6/M6_REPOSITORY_IMPLEMENTATION_EVIDENCE.md)	M7 unblocked
M7 Deployment Identity / Platform Mutation	COMPLETE / VERIFIED PASS (2026-08-14, all 9 Exit Gate criteria met)	RUNBOOK READY + repo evidence	ADR-0061	read-only Render preflight done; deployment merged and confirmed gated on M6 attestation on a real push; post-deploy identity/health verification confirmed end-to-end against the live Render deploy after a	M8 unblocked, not yet started

Phase	Execution State	Documentation Readiness	Authority	Mutation / Test Gate	Next Gate
				real bug fix (docs/evidence/m7/M7_PHA- SE0_AND_REPO-SITO- RY_CON- TROLS_EVIDENCE.md); Owner performed a real deploy-hook rotation, confirmed via 3 independent sources (docs/runbooks/M7_DE- PLOY_HOOK_ROTATION_HANDOFF.md); Owner performed a real Render Dashboard rollback plus roll-forward to current main, both confirmed via 3 independent sources each (docs/runbooks/M7_ROLL-BACK_VERIFICATION_HANDOFF.md); all 10 Required Negative Tests now have a concrete, automated, passing test (docs/evidence/m7/M7_REQUIRED_NEGATIVE_TESTS_EVIDENCE.md)	
M8 Agent Cutover	COMPLETE / VERIFIED PASS (2026-08-16, all 9 Exit Gate items PASS)	RUNBOOK READY + repo evidence	ADR-0062 + ESS-0019	Provider Profile Registry, Policy-Equivalence, rollback-to-read-only, audit correlation (PR #308) and provider-specific-bypass-denial (PR #328) all	M9 unblocked (Integrated Roadmap Phase I2); each M9 drill remains separately Owner-authorized

Phase	Execution State	Documentati-on Readiness	Authority	Mutation / Test Gate	Next Gate
				verified; externalHost- Configuratio- nVerified for chatgpt- github- connector ve- rified read-only 2026-08-16 (docs/evidence/m8/ M8_EXTER- NAL_HOST_CONFIGURATION_VERIFIED_EVIDENCE. Exit-Gate-Punkt 2 closed under Owner-accepted scope decision — "privileged supported provi- ders" = muta- ting providers with a producti- on host, i.e. chatgpt- github- connector only; claude- code-cli structurally BLOCKED and explicitly not a supported privi- leged path (docs/evidence/m8/ M8_E- XIT_GA- TE_I- TEM2_SC0- PE_DECISI- ON.md , OW- NER_ACCEPTED); canonical provi- der set corrected 2026-08-16 (PR #365) to ChatGPT/Claude/Grok — google-ai- studio / note- booklm / gemi- ni are now	

Phase	Execution State	Documentation Readiness	Authority	Mutation / Test Gate	Next Gate
				RETI-RED_PROVIDER_ALIASES (DENY), and grok-xai-connector is BLOCKED for the same structural reason as claude-code-cli . Full closure: docs/evidence/m8/M8_CLOSURE_EVIDENCE.md	
M9 Assurance / Incident / Break-Glass	UNBLOCKED — not yet started (M8 VERIFIED PASS as of 2026-08-16)	RUNBOOK READY	ADR-0063	injection/replay/exfiltration/audit/kill-switch/break-glass/rollback drills	M10 after assurance VERIFIED PASS
M10 Passkey-only Owner PR Authorization	BLOCKED BY M9	ESS + RUNBOOK + THREAT MODEL READY	ADR-0066 + ESS-0022	exact-state WebAuthn approval, shadow mode, replay/recovery tests, legacy gate cleanup	Development-Chain closure after VERIFIED PASS

Documentation readiness never authorizes blocked phase execution.

M7 closure — Current executable DEVELOPMENT phase is now M8

M5A und M6 sind VERIFIED PASS (2026-08-14) — siehe docs/evidence/m5a/M5A_VERIFIED_PASS_CLOSURE_EVIDENCE.md und docs/evidence/m6/M6_REPOSITORY_IMPLEMENTATION_EVIDENCE.md .

M7 (Deployment Identity) — Phase-0-Preflight (read-only) abgeschlossen: exakt ein Render-Service identifiziert (srv-d91o1o9o3t8c73edi55g , „Finance“), aktueller live Deploy bestätigt konsistent mit main , bestehender Health-/Deployment-Identitäts-Mechanismus (ADR-0036) inspiziert, keine GitHub-OIDC- Föderation zu Render verfügbar. Erstes Repository-Implementation-Paket (Owner-bestätigter Scope: Provenance-Gate + Post-Deploy-Verifikation) ist **VERIFIED PASS** auf dem realen Build-/Deploy-Pfad: deploy-production hängt zusätzlich von supply-chain-attestation ab und wurde real bestätigt fail-closed korrekt darauf zu warten. Der neue Job verify-deployment-identity schlug in seinem ersten echten Lauf fehl (er las die Deployment-Identität nur aus dem JSON-Body, während Produktion sie ausschließlich über Response-Header liefert — ein echter, im realen Lauf gefundener Bug); nach Root-Cause- Fix lief der zweite reale push -Lauf vollständig PASS:

PASS nach 5 Versuch(en), 40871ms, Commit live und healthy bestätigt (Run [31843242491](#)).
 Siehe `docs/evidence/m7/M7_PHASE0_AND_REPOSITORY_CONTROLS_EVIDENCE.md`.

Zweites Element (Owner-Anweisung „fang mit M8 an“ → M8 blockiert, bis M7 vollständig VERIFIED PASS ist → Owner wählt „M7 zuerst vollständig abschliessen“ und bestätigt als konkretes Mutationsziel die Rotation des Render-Deploy-Hooks): der Owner hat den Deploy-Hook direkt im Render-Dashboard rotiert und das GitHub-Secret `REN-
DER_DEPLOY_HOOK_URL` aktualisiert (Work Order: `docs/runbooks/M7_DE-
PLOY_HOOK_ROTATION_HANDOFF.md`). Drei unabhängige Nachweise bestätigen Erfolg: GitHub-Actions-Job-Log (neuer Hook liefert gültige Deploy-ID), Render-Deploy-Historie (dieselbe Deploy-ID, `status: live`, korrekter Commit) und `verify-deployment-identity` PASS. Rotation/Revocation der Deployment-Credential-Bridge ist damit real bewiesen.

Drittes Element (Owner-Anweisung „fang mit dem Rollback-Nachweis an“ für Exit-Gate-Punkt 7): der Owner hat direkt im Render-Dashboard einen echten Rollback auf den vorherigen Live-Deploy (`dep-d9vp043m8hqs73dv238g`, Commit `8b4-cab066c7c893c4525cd8e015e80919b145bde`) durchgeführt (Work Order: `docs/runbooks/M7_ROLL-BACK_VERIFICATION_HANDOFF.md`). Renders eigene Deploy-Historie bestätigt den Erfolg unabhängig: der resultierende Deploy `dep-d9vpuru1egvs73f7684g` trug `status: live` und `trigger: rollback` — Renders eigene Klassifizierung des Auslösers, nicht `deploy_hook` — als plattformseitiger Nachweis, dass die echte Rollback-Funktion (nicht ein normales Redeploy) verwendet wurde. Als Nebenwirkung wurde ein konkurrierender, durch PR #275 ausgelöster Deploy auf `canceled` gesetzt, wodurch Produktion vorübergehend hinter dem aktuellen `main` (inkl. PR #274 und PR #275) zurücklag. Der Roll-Forward erfolgte bewusst über den regulären CI-gegateten Pfad — durch das Mergen von PR #277, der den Rollback-Nachweis trug — statt über einen direkten `trigger_deploy`-Aufruf, um das M6-Attestation-Gate nicht zu umgehen. Der resultierende `push`-Lauf [31850025365](#) bestätigte den Roll-Forward dreifach unabhängig: GitHub-Actions-Log (`deploy-production` lieferte `dep-d9vq75c9v7es73fu2uh0` für Commit `28917b08...`), Render-Deploy-Historie (`status: live`, `trigger: deploy_hook`, alter Rollback-Deploy sauber auf `deactivated`) und `verify-deployment-identity` (PASS nach 4 Versuch(en), 32206ms). Produktion ist damit wieder vollständig mit `main` synchron. M7-Exit-Gate-Punkt 7 ist damit vollständig geschlossen — sowohl Rollback als auch Roll-Forward real durchgeführt und unabhängig verifiziert.

Viertes Element (Owner-Anweisung „fang mit der Required Negative Tests Liste an“ für Exit-Gate-Punkt 6): da die DEVELOPMENT Chain Mutation Handoff Contract (`.ai/contracts/development-chain-mutation-handoff.schema.json`) nie einen Validator hatte — ihr `executor-AgentId` ist fest auf den SA3B/GitHub-Executor gebunden, der für Render nie existiert hat — wurde `src/platform/Security/developmentChainMutationHandoff.ts` neu gebaut (strukturvalidierend + Ausführungszeit-Gate, exakt nach dem Muster des bereits produktiven `roadmapExecutionMandate.ts`). Alle 10 im Runbook gelisteten „Required Negative Tests“ haben jetzt einen konkreten, automatisierten, real laufenden Test: 20 neue Tests für den Handoff-Validator/-Gate, 5 für statische CI-Guards (`deploy-production` / `supply-chain-attestation` / `verify-deployment-identity` laufen nachweislich nur bei `push` auf `main`), 2 Integrationstests, die den echten `verifyDeploymentIdentity`-Subprozess gegen einen Mock-Server fail-closed scheitern lassen (Exit-Code $\neq 0$, `FAILED` / `TIMEOUT`-Evidence) — dieselbe Eigenschaft, die

bereits einmal real in Produktion beobachtet wurde. Vollständiger Suite-Lauf: 901 Tests, alle PASS. Details: `docs/evidence/m7/M7_REQUIRED_NEGATIVE_TESTS_EVIDENCE.md`.

M7-Exit-Gate-Neubewertung — alle 9 Punkte explizit geprüft (siehe `docs/runbooks/M7_DEPLOYMENT_IDENTITY_MUTATION.md` Abschnitt „Exit Gate Closure“ für die vollständige Begründung je Punkt): M6-Voraussetzung verifiziert; Repository-Controls gemerged/validiert; alle erforderlichen externen Mutationen (Rotation, Rollback, Roll-Forward) separat Owner-freigegeben; alle `VERIFIED PASS`; Deployment-Identität bindet verifizierte Quelle an Laufzeit; Negativtests bestehen; Rollback ist bewiesen; Evidence/Roadmap/Traceability synchron (dieser Commit); Work Branches gelöscht (per `git ls-remote` bestätigt — Repository löscht Head-Branche automatisch nach Merge).

M7 ist damit `COMPLETE / VERIFIED PASS` (2026-08-14). **M8 ist entsperrt**, aber noch nicht begonnen — ein Start erfordert weiterhin eine separate, ausdrückliche Owner-Anweisung. Jede künftige externe Plattform-Mutation braucht weiterhin ihr eigenes exaktes Ziel + separate Owner-Mutation-Approval. SA5 bleibt weiterhin bis M10 `VERIFIED PASS` blockiert.

M8 Start (Owner-Anweisung „fang mit M8 an“)

Phase-0-Preflight (read-only) abgeschlossen: alle 6 Prerequisite-Gate-Punkte geprüft und erfüllt. Wichtigster Einzelbefund: die MCP-Tool-Aufrufe dieser (und jeder) interaktiven Claude-Code-Sitzung laufen nicht durch `agentIam.ts` — dieser Tool-Grant kommt aus der äußeren CCR-Umgebung, nicht aus diesem Repository, und ist daher nicht durch eine Code-Änderung schließbar. Details: `docs/evidence/m8/M8_PHA-SEQ0_AND_PROVIDER_PROFILE_EVIDENCE.md`.

Owner wählt als erstes Repository-Implementation-Paket „Provider Profile Contract + Registry“: `src/platform/Security/providerProfile.ts` (neu) definiert Profile für alle 4 in `AI_AGENT_PROVIDER_PROFILE_CONTRACT.md` dokumentierten Provider (ChatGPT, Claude Code, Google AI Studio, NotebookLM) und schränkt den bestehenden `agentIam.ts`-Kernel nur ein, ersetzt ihn nie — exakt nach dem Muster von `roadmapExecutionMandate.ts` (SA1). Alle im Runbook geforderten Policy Equivalence Tests und Negative Tests bestehen (23 neue Tests). Voller Suite-Lauf: 930 Tests, alle PASS.

Zweites Element (Owner-Anweisung „Policy Equivalence gegen einen echten Aufrufer verdrahten“): `checkProviderProfileScope()` (neu, aus `providerProfile.ts` herausgezogen, damit die generische M8-Prüfung `agentIam.ts` nicht ein zweites Mal mit einem eigenständig konstruierten Approval-Objekt aufruft — das hätte reale HIGH-Risk-Anfragen fälschlich verweigert) ist jetzt in `server/agentAudit/systemadminAuditedExecution.ts` (SA3, aktiver SA3B-Host) eingehängt: additiv, ausschließlich einschränkend, nie ersetzend. Ein Drift-Guard-Test beweist, dass das neue `chatgpt-github-connector`-Profil exakt dieselben Capabilities trägt wie das bestehende SA2-Chat-Profil; ein End-to-End-Test beweist, dass die tatsächlich live genutzte Capability (`BRANCH`, `MEDIUM`-Risiko) durch die komplette Kette inklusive der neuen Schicht unverändert `ALLOW` liefert. Alle 6 bestehenden SA3-Tests bestehen unverändert. Voller Suite-Lauf: 949 Tests, alle PASS.

Drittes Element (Owner-Anweisung „fahre mit Roadmap fort“, bei fehlender Präferenz gewählt: Rollback-zu-read-only beweisen — M8-Exit-Gate-Punkt 6): Befund vor der Umsetzung — der einzige bisher verdrahtete Kill-Switch (`mandate.killSwitch.enabled`) verweigert bei Deaktivierung alles, inklusive `READ` , zu strikt für „restore read-only operation“. `agentIam.ts` s eigener `killSwitchActive` -Mechanismus erhält gezielt `READ / ANALYZE / PLAN` , war aber nicht durch die SA1-REM-Kette hindurch verdrahtet. Geschlossen durch ein neues, optionales `killSwitchActive` -Feld auf `SystemadminRoadmapAuthorizationRequest` (additiv, Standard unverändert), das automatisch durch die gesamte bestehende Kette fließt. Zweiter, unabhängiger Rollback-Hebel: `checkProviderProfileScope()` erhält ein optionales `registry` -Parameter, das beweist, dass ein deaktiviertes Provider-Profil (`allowedCapabilities` verengt) unabhängig ebenfalls verweigert, ohne die reale `PROVIDER_PROFILES` -Registry je zu mutieren. Beide Hebel end-to-end durch die echte, live verdrahtete SA3B-Kette bewiesen (nicht nur isolierte Unit-Tests): die tatsächlich live genutzte Capability `BRANCH` wird verweigert, `READ` bleibt erlaubt. 7 neue Tests, bestehende SA1/SA2/SA3-Tests unverändert. Voller Suite-Lauf: 975 Tests, alle PASS.

M8 als Ganzes bleibt PLANNED , nicht `COMPLETE / VERIFIED PASS` : Claude Code, Google AI Studio und NotebookLM haben weiterhin keinen echten Aufrufer (der Rollback-Nachweis gilt daher nur für den verdrahteten SA3B-Pfad), keine direkte Provider-Zugriffsmethode wurde deaktiviert, und die Cutover-Sequenz hat nicht begonnen.

Goal

Replace the historical application-owned TOTP assurance for privileged identities with authoritative Supabase Native MFA/AAL2 enforcement while retaining purpose-bound application step-up only as defense-in-depth.

Required sequence

1. architecture/runbook accepted;
2. fresh implementation branch from then-current `main` ;
3. native TOTP enroll/challenge/verify integration;
4. centralized server-side AAL2 gate;
5. privileged session/factor lookup fail-closed;
6. recovery/factor reset aligned with native MFA;
7. positive + negative tests;
8. repository CI `VERIFIED PASS` ;
9. read-only production precheck;
10. separate explicit Owner mutation approval;
11. native Owner-factor mutation one identity at a time;
12. AAL2 positive/negative/recovery verification;
13. advisor/evidence rerun;
14. Roadmap/Traceability sync.

Mutation boundary:

- repository code: `REQUIRED` ;
- Owner Native MFA enrollment: `REQUIRED / NOT YET AUTHORIZED` at baseline;
- Supabase project setting: `CONDITIONAL` only if exact need is proven;
- new Postgres DDL: `NOT REQUIRED` ;
- Stripe/Render: `NOT REQUIRED` for M5A.

M6 — Supply Chain Provenance

Runbook: `docs/runbooks/M6_SUPPLY_CHAIN_PROVENANCE.md` .

Required deliverables:

- deterministic dependency resolution from committed lockfile;
- exact source SHA and lockfile digest;
- machine-readable SBOM;
- source-to-artifact provenance;
- signed/verifiable attestation appropriate to the available hosted build environment;
- artifact digest bound to provenance;
- pinned/least-privilege CI actions;
- vulnerability and supply-chain checks;
- immutable release/rollback reference;
- Evidence under `docs/evidence/m6/` .

M5A ist `VERIFIED PASS` (2026-08-14, `docs/evidence/m5a/M5A_VERIFIED_PASS_CLOSURE_EVIDENCE.md`). M6-Implementierung ist damit zulässig, aber ein separater, noch zu beauftragender Schritt.

M7 — Deployment Identity and Platform Mutation

Runbook: `docs/runbooks/M7_DEPLOYMENT_IDENTITY_MUTATION.md` .

Required deliverables:

- exact production deploy identity and trust boundary;
- source/provenance → deployment → runtime identity correlation;
- environment-scoped Render deployment path;
- credential/hook ownership, rotation and revocation;
- exact mutation work order for every external change;
- pre/post health/readiness and rollback verification;
- Stripe/Supabase only when separately named by Authority;
- DNS/TLS/IONOS remains Human/Owner-reserved absent a later stronger ADR.

M8 — Provider-neutral Agent Cutover

Runbook: `docs/runbooks/M8_AGENT_CUTOVER.md` .

Target:

```
AI App / Agent
→ provider profile
→ CAPITAL-AI Control Plane
→ IAM / risk / audit / execution-host decision
→ bounded capability
```

Required:

- ChatGPT, Claude and Google AI Studio transports mapped to the same semantic capability policy;
- no provider-specific direct admin path becomes canonical;
- research/read-only profiles remain mutation-denied;
- negative tests prove provider name/model cannot elevate authority;
- rollback disables mutation/cutover profile and restores read-only operation.

M9 — Assurance

Runbook: `docs/runbooks/M9_ASSURANCE_INCIDENT_BREAK_GLASS.md` .

Exit evidence must cover:

- prompt/tool injection;
- authorization bypass;
- replay/idempotency;
- secret/data exfiltration;
- audit completeness and audit outage;
- mutation kill switch;
- break-glass procedure;
- rollback/recovery drill;
- independent Evidence review;
- no unowned CRITICAL control.

M10 — Passkey-only Human/Owner PR Authorization

Authorities:

- `docs/adr/ADR-0066-passkey-only-owner-pr-authorization.md` ;
- `.ai/skills/ESS-0022-Passkey-Only-Owner-PR-Authorization.md` ;
- `docs/runbooks/M10_PASSKEY_OWNER_PR_AUTHORIZATION.md` ;
- `docs/architecture/ai-agent/M10_PASSKEY_OWNER_PR_AUTHORIZATION_THREAT_MODEL.md` .

Target sequence:

```
PR OPEN/UPDATE
→ Human file review / Viewed
→ exact PR-state resolution
→ server-generated single-use WebAuthn challenge
→ Owner passkey assertion with required user verification
→ server verifies RP/origin/credential/signature/UP/UV/state freshness
→ immutable approval evidence
→ exactly one CI request consumes approval
→ build-and-test
→ Human merge
```

Legacy `/ okay` and Owner checkbox authorization remain authoritative until controlled M10 cutover reaches `VERIFIED PASS` .

Mutation Executor Handoff

Canonical documents:

- `docs/contracts/DEVELOPMENT_CHAIN_MUTATION_HANDOFF_CONTRACT.md` ;
- `.ai/contracts/development-chain-mutation-handoff.schema.json` .

A Handoff contains exact phase/item/base/target/operation/precheck/postcheck/rollback/evidence metadata but **cannot create authority**. Execution separately requires the applicable Human Approval, REM/IAM/Execution Host policy and durable audit evidence.

Branch / Clone Lifecycle

For every work item:

```
current main → fresh scoped branch → PR → Human merge → branch delete
```

Cloned repositories, worktrees and agent workspaces never edit `main` directly. After successful merge, the Finance remote work branch is deleted and temporary workspaces are cleaned after Evidence retention. The next work item starts again from then-current `main` .

Authority: `docs/governance/DEVELOPMENT_CHAIN_BRANCH_LIFECYCLE_POLICY.md` .

Required Documentation Set per Phase

Each roadmapped phase closes only when applicable classes are covered:

1. Roadmap + ESS/ADR Authority;
2. Threat/Risk model for new trust boundaries;
3. Runbook;
4. machine contract for agentic/platform Handoff where relevant;
5. positive + negative tests;
6. mutation approval/pre/post/rollback when relevant;
7. redacted append-only Evidence;

8. traceability requirement → implementation → test → evidence → state;
9. Human merge + branch deletion for repository changes;
10. explicit Next Gate.

Current Next Action

M5A is VERIFIED PASS (2026-08-14). M6 (Supply Chain Provenance) is the next DEVELOPMENT Chain gate. M6–M10 documentation is prepared in advance only to remove planning gaps; M7–M10 remain blocked by their sequential predecessors.

Nächster zulässiger Auftrag: M5 Audit-Evidence und M5A AAL2-/DENY-/Recovery-/Advisor-Evidence read-only vervollständigen. Mutation Requests dürfen vom Owner oder System-administrator-Agenten initiiert werden; jede externe oder sicherheitsrelevante Ausführung benötigt weiterhin ein exaktes Proposal und ausdrückliche Owner-Freigabe gemäß ADR-0071/ESS-0023.

CAPITAL-AI Integrated Development Chain + Systemadmin Roadmap

Quelle: docs/roadmaps/INTEGRATED_DEVELOPMENT_SYSTEMADMIN_ROADMAP.md

CAPITAL-AI Integrated Development Chain + Systemadmin Roadmap

Document ID: ROADMAP-INTEGRATED-DC-SA-0001

Status: ACTIVE — CANONICAL EXECUTION ROADMAP

Version: 1.0.4

Date: 2026-08-16

Repository: SvenKulesa/Finance

Authority: ADR-0071, ESS-0023, DEVELOPMENT_CHAIN_EXECUTION_POLICY, SYSTEMADMIN_AGENT_ROADMAP_EXECUTION_POLICY, DOCUMENTATION_HYGIENE_POLICY

Owner: SvenKulesa

1. Zweck

Dieses Dokument ist die **einzige kanonische Ausführungsroadmap**, die die DEVELOPMENT Chain (M0-M10) und den Systemadmin-Agenten (SA0-SA5) verbindet.

Es nimmt alle offenen Lücken, Verbesserungsvorschläge und Evidence-Gaps aus den bisherigen Einzel-Roadmaps, dem Architecture Gap Report und den Konsolidierungs-Indizes auf und überführt sie in einen sequenziellen, fail-closed Ausführungsplan.

Es ersetzt keine restriktivere ADR-, ESS-, IAM-, REM-, Runbook- oder Human/Owner-Authority.

Bei Widerspruch gilt immer die restriktivere Regel.

2. Verbindliche Authority-Reihenfolge

1. Verifizierte Runtime-, Code- und Produktions-Evidence
 2. Ausdrückliche Human/Owner-Freigabe
 3. Spezifische ADR / ESS / IAM / REM / Runbook
 4. Diese Integrated Roadmap
 5. Fach-Roadmaps (SEO-GM, S1, Documentary etc.)
 6. Historische / SUPERSEDED Indizes (nur Evidence-Wert)
-

3. Integrierte Phasen-Matrix

Phase	DEVELOPMENT Chain	Systemadmin	Execution State	Mutation Gate	Next Gate
I0	M0-M7 Baseline	SA0-SA4 Baseline	VERIFIED PASS	read-only preserve	I1
I1	M8 Agent Cutover (Abschluss)	Work-Package Catalog Nutzung	VERIFIED PASS (2026-08-16) — alle 9 Exit-Gate-Punkte PASS; Exit-2 unter Owner-akzeptiertem Scope geschlossen (M8_E-XIT_GATE_I-TEM2_SCOPE_DECISION.md , OWNER_ACCEPTED)	repository only, REM-bound	I2 unblocked
I2	M9 Assurance / Incident / Break-Glass	SA-Prototyp-Anfragen (ESS-0023)	UNBLOCKED — not yet started (M8 VERIFIED PASS)	drills + evidence, jeder Drill einzeln Owner-autorisiert	I3 nach VERIFIED PASS
I3	M10 Passkey-only Owner PR Authorization	SA5 Design-Vorbereitung	BLOCKED	exact-state WebAuthn	I4 nach VERIFIED PASS
I4	Development-Chain Closure	SA5 Bounded External Mutation Design	BLOCKED	separate ADR + Owner Approval	Production Mutation möglich

Regel: Documentation readiness authorizes never blocked phase execution.

4. I1 — M8 Agent Cutover (aktueller ausführbarer Fokus)

Goal

Provider-neutraler Agent-Cutover: privilegierte Execution über denselben Control-Plane-Pfad mit identischer Capability-Policy. Kein provider-spezifischer privilegierter Bypass bleibt kanonisch.

Stand 2026-08-16 (Evidence) — I1 abgeschlossen

- Phase 0 + Provider-Profile + SA3B-Verdrahtung + Rollback + Bypass-Audit + Audit-Korrelation: **VERIFIED PASS**
- chatgpt-github-connector : alle 6 ProviderCutoverEvidence -Felder **true** inkl. externalHost-ConfigurationVerified (docs/evidence/m8/M8_EXTERNAL_HOST_CONFIGURATION_VERIFIED_EVIDENCE.md) → Readiness **READY**

- Kanonisches Provider-Set korrigiert 2026-08-16 (PR #365, docs/evidence/m8/M8_PROVIDER_SET_CORRECTION_2026-08-16.md): **ChatGPT, Claude, Grok**. google-ai-studio / notebook-klm / gemini sind jetzt **RETIRED** (DENY im Control Plane), nicht mehr Teil der Matrix
- claude-code-cli: **BLOCKED** strukturell (docs/architecture/M8_CLAUDE_CODE_REAL_CALLER_DESIGN.md) — kein unterstützter privilegierter Produktionspfad
- grok-xai-connector: **BLOCKED** aus demselben strukturellen Grund (interaktive, host-vermittelte Connector-Sitzung ohne code-adressierbaren Execution-Host) — kein unterstützter privilegierter Produktionspfad
- Exit-Gate-Punkt 2: **OWNER_ACCEPTED** (2026-08-16, explizite Owner-Antwort "ACCEPT (empfohlen)" via AskUserQuestion) — docs/evidence/m8/M8_EXIT_GATE_ITEM2_SCOPE_DECISION.md
- M8 Closure: docs/evidence/m8/M8_CLOSURE_EVIDENCE.md — **COMPLETE / VERIFIED PASS**

Systemadmin-Rolle in I1

- Darf bounded Work-Packages aus dem generalisierten Catalog (ADR-0074) für M8-Dokumentation und Tests ausführen
- Darf Mutation Proposals an den Owner stellen (ESS-0023)
- Darf **keine** Provider-Profile oder IAM-Regeln eigenmächtig erweitern
- Execution nur über trusted GitHub Actions Host + OIDC + REM

Exit Gate I1 (Runbook-9-Punkte, maßgeblich) — 9/9 PASS

1. M7 verified — **PASS**
2. Privileged supported providers on Control Plane — **PASS** (Owner-akzeptierter Scope: mutierende Provider mit produktivem Host = chatgpt-github-connector)
3. Policy equivalence — **PASS**
4. No provider-specific privileged bypass — **PASS**
5. Research profiles fail mutation — **PASS**
6. Rollback-to-read-only — **PASS**
7. Audit correlation — **PASS**
8. Evidence + Traceability sync — **PASS** (dieser PR + M8_CLOSURE_EVIDENCE.md)
9. Work branches deleted — **N/A / PASS** (kein offener M8-Cutover-Branch)

5. I2 — M9 Assurance (nach I1)

Goal

Nachweis, dass die Control Plane gegen Injection, Authorization-Bypass, Replay, Exfiltration, Audit-Outage und Kill-Switch resistent ist und Break-Glass + Rollback funktionieren.

Required Deliverables

- Prompt/Tool-Injection-Tests

- Authorization-Bypass-Negative-Tests
- Replay/Idempotency-Proof
- Secret/Data-Exfiltration-Guard
- Audit-Completeness + Outage-Verhalten
- Mutation Kill-Switch
- Break-Glass-Procedure (real drill)
- Rollback/Recovery-Drill
- Independent Evidence Review
- Kein unowned CRITICAL Control

Systemadmin-Rolle

- Darf Assurance-Evidence-Work-Packages ausführen
- Darf Kill-Switch- und Break-Glass-Proposals formulieren
- Ausführung der Drills bleibt Human/Owner-gesteuert

Startbedingung: M8 COMPLETE / VERIFIED PASS inkl. Owner-ACCEPT auf Exit-Gate-2-Scope.

6.13 — M10 Passkey-only Owner PR Authorization

Goal

Exact-state WebAuthn (Passkey) mit User-Verification für AUTHORIZE_PR_CI (Legacy-Emoji/Checkbox-Gates sind bereits retired; M10 ist die nächste starke Schicht).

Sequence

```
PR OPEN/UPDATE
→ Human file review / Viewed
→ exact PR-state resolution
→ server-generated single-use WebAuthn challenge
→ Owner passkey assertion (UV required)
→ server verifies RP/origin/credential/signature/UP/UV/state freshness
→ immutable approval evidence
→ exactly one CI request consumes approval
→ build-and-test
→ Human merge
```

Systemadmin-Rolle

- Darf Shadow-Mode und Threat-Model-Evidence liefern
 - Darf **keine** Passkey-Enrollment oder Recovery-Codes mutieren
-

7.14 — SA5 + DevelopmentChain Closure

Nach M10 VERIFIED PASS : - SA5 Bounded External Mutation Design (separate ADR erforderlich) - DEVELOPMENT Chain Closure Evidence - Alle Arbeitsbranches gelöscht - Traceability-Matrix vollständig

8. Übernommene Lücken & Verbesserungsvorschläge

Aus Architecture Gap Report (historisch, teilweise geschlossen)

- Event-Bus und Registry existieren jetzt (EventMesh)
- Tests existieren in großer Zahl
- Viele Metadata-Gaps sind durch spätere ADRs geschlossen
- Verbleibend: kontinuierliche Manifest- und component.yaml-Hygiene, Digital-Twin-Verträge, vollständige AI-Orchestration-Contracts

Aus aktuellen Roadmaps

- S1 Security Hardening Revalidation (F-01-F-18 gegen current main)
- Documentary Event Value Chain (D0 Baseline)
- SEO-GM-ROADMAP-0002 (Single Point of Trust)
- AI-Content-Transparency-Contract (P0)
- Continuous Vocabulary Governance

Verbesserungsvorschläge (Best Practice / SOTA 2026)

1. **Parallelisierung mit Isolation** — Bounded Work-Packages dürfen parallel laufen, solange Path-Overlap und Capability-Ceiling fail-closed geprüft werden (bereits teilweise in ADR-0074)
2. **SLSA Level 4 Ziel** — aktuelle cosign keyless + OIDC ist stark; nächster Schritt: in-toto + Rekord permanente Transparenz
3. **Passkey + Hardware-Bound** — M10 bereits geplant; Hardware-Attestation als optionale Stufe
4. **Observability Correlation** — OpenTelemetry End-to-End von Agent-Action bis Deploy-Identity (teilweise in M5/M7)
5. **Document Hygiene Automation** — H5 Gate bereits in Unit-Tests; ausbauen auf automatische SUPERSEDED → archive Verschiebung

Alle Punkte werden in die jeweiligen Phasen (I1-I4) oder als parallele Bounded Work-Packages aufgenommen.

9. Dokumentationshygiene — Archivierung

Gemäß `docs/governance/DOCUMENTATION_HYGIENE_POLICY.md` und `docs/archive/README.md`:

Sofort als **SUPERSEDED** markieren und nach `docs/archive/legacy/` verschieben (bzw. Status setzen)

- `docs/roadmaps/MARKETING_AGENT_ROADMAP.md` → bereits als SUPERSEDED markiert (SEO-GM)
- `docs/seo/SEO_MANAGEMENT_ROADMAP.md` → bereits als SUPERSEDED markiert (SEO-GM)

- `docs/architecture/ARCHITECTURE_GAP_REPORT.md` → historischer Snapshot (viele Gaps geschlossen); Evidence-Wert behalten unter `docs/archive/evidence/`

Beibehalten (kanonisch)

- `docs/roadmaps/DEVELOPMENT_CHAIN_ROADMAP.md` (Detail-Phasen)
- `docs/roadmaps/SYSTEMADMIN_AGENT_ROADMAP.md` (Detail-SA)
- `docs/roadmaps/ROADMAP_CONSOLIDATION_MASTER_INDEX.md` (Portfolio-Index)
- Diese Integrated Roadmap (neue kanonische Ausführungsautorität)

Regel

Historische Evidence wird **niemals gelöscht**, nur archiviert. Canonical Documents behalten stabile `documentId`. Pfad ist mutable Metadata.

10. Branch- & Mutation-Lifecycle (unverändert)

```
current main
→ fresh scoped branch
→ REM / Handoff / Owner Approval (wenn mutation)
→ audited actions (BRANCH → COMMIT → PR)
→ Human file review + CI
→ Human merge
→ branch delete
→ append-only Evidence
→ Roadmap / Traceability Sync
→ next phase
```

Kein Agent darf `main` direkt schreiben.

Kein Document erzeugt eigene Authority.

11. Current Next Action (I1 abgeschlossen → I2)

I1 erledigt (2026-08-16): 1. PR `docs/m8-exit-gate-a-b-c-2026-08-16` gemergt (PR #362) 2. Owner hat in `docs/evidence/m8/M8_EXIT_GATE_ITEM2_SCOPE_DECISION.md` **ACCEPT** gesetzt (explizite Antwort via `AskUserQuestion`) 3. M8 Closure Evidence (`docs/evidence/m8/M8_CLOSURE_EVIDENCE.md`) + Roadmap-Status `VERIFIED PASS` + Freigabe I2/M9 — dieser PR

I2 (M9 Assurance) ist jetzt der aktive Fokus, aber: - Kein einzelner M9-Drill (Prompt/Tool-Injection, Authorization-Bypass, Replay, Exfiltration, Audit-Outage, Kill-Switch, Break-Glass, Rollback) startet automatisch — jeder braucht eine eigene, konkrete Owner-Anweisung. - **I2-Bestandsaufnahme erledigt (2026-08-16):** `docs/evidence/m9/M9_I2_ENTRY_INVENTORY_AND_GAP_ANALYSIS_2026-08-16.md` — Prerequisite Gate 7/7 erfüllt, Bestand je Assurance-Domain bewertet (stärkste Grundlage: Kill-Switch/Rollback, schwächste: Prompt/Tool-Injection und Break-Glass — Letzteres braucht zuerst einen Owner-Proposal, da ADR-0063 noch `PROPOSED` ist), priorisierter Vorschlag für die Drill-Reihenfolge dokumentiert. - **Kill-Switch-Live-Drill erledigt (2026-08-16):** Owner-Wahl „Kill-Switch-Live-Drill (empfohlen)“ via `AskUserQuestion` → `docs/evidence/m9/`

M9_KILL_SWITCH_LIVE_DRILL_2026-08-16.md . Alle vier realen mutierenden Capabilities gegen die live-wired SA3B-Kette angegriffen und verweigert; READ/ANALYZE/PLAN bleiben erhalten; 9 neue Tests, 1086/1086 gesamt PASS. Trägt zu M9-Exit-Gate-Punkt 3 bei (teilweise — nur SA3B als einziger produktiver Aufrufer). - Nächster Schritt: Owner wählt den nächsten konkreten Drill (Rollback/Recovery empfohlen als nächststärkste Grundlage) — siehe Priorisierungsvorschlag im Inventory-Dokument §5.

Nicht ausführbar ohne separate Owner-Freigabe: - M9-Drills / M10 / SA5 - Claude-Code Real-Caller (eigenes ADR erforderlich) - Jede Produktions-, IAM-, Secret-, Deploy- oder HIGH/CRITICAL-Mutation

12. Abschlusskriterien der Integrated Roadmap

Die Roadmap gilt als geschlossen, wenn:

- I0-I4 alle VERIFIED PASS
 - P0/P1 Prioritäten geschlossen oder Owner-akzeptiert
 - Kein unowned HIGH/CRITICAL Control
 - Alle produktiven Mutationen Owner-genehmigt und evidence-gebunden
 - Traceability-Matrix vollständig
 - Alle SUPERSEDED-Dokumente archiviert
 - Alle gemergten Arbeitsbranches gelöscht
-

Related Documents

- docs/roadmaps/DEVELOPMENT_CHAIN_ROADMAP.md
 - docs/roadmaps/SYSTEMADMIN_AGENT_ROADMAP.md
 - docs/roadmaps/ROADMAP_CONSOLIDATION_MASTER_INDEX.md
 - docs/governance/DEVELOPMENT_CHAIN_EXECUTION_POLICY.md
 - docs/governance/SYSTEMADMIN_AGENT_ROADMAP_EXECUTION_POLICY.md
 - docs/governance/DOCUMENTATION_HYGIENE_POLICY.md
 - docs/contracts/DEVELOPMENT_CHAIN_MUTATION_HANDOFF_CONTRACT.md
 - docs/adr/ADR-0071-consolidated-roadmap-and-requested-systemadmin-mutations.md
 - docs/adr/ADR-0074-generalized-systemadmin-work-package-catalog.md
 - .ai/skills/ESS-0023-Consolidated-Systemadmin-Prototype-and-Mutation-Request.md
 - docs/evidence/m8/M8_EXTERNAL_HOST_CONFIGURATION_VERIFIED_EVIDENCE.md
 - docs/evidence/m8/M8_EXIT_GATE_ITEM2_SCOPE_DECISION.md
-

Version History

Version	Date	Description
1.0.0	2026-08-15	Initial Integrated Roadmap — connects DC + SA, absorbs all open gaps and improvement suggestions
1.0.1	2026-08-16	I1 sync: externalHostConfiguration-Verified PASS; Exit-Gate-2 Scope-Proposal; M9 remains blocked
1.0.2	2026-08-16	I1 COMPLETE / VERIFIED PASS: Owner accepted Exit-Gate-2 scope decision; M8 Closure Evidence; I2 (M9) unblocked as a phase, each drill still separately Owner-authorized
1.0.3	2026-08-16	I2 entry: read-only inventory/gap analysis (M9_I2_ENTRY_INVENTORY_AND_GAP_ANALYSIS_2026-08-16.md) — no drill executed; priority proposal for Owner drill selection
1.0.4	2026-08-16	I2: Kill-Switch-Live-Drill Owner-authorized and executed (M9_KILL_SWITCH_LIVE_DRILL_2026-08-16.md) contributes to M9 Exit Gate item 3 (partial, SA3B only)

End of Document

ROADMAP-INTEGRATED-DC-SA-0001
CAPITAL-AI Integrated Development Chain + Systemadmin Roadmap
Version 1.0.4

M5A Systemadmin Repository Work Package

Quelle: docs/roadmaps/M5A_SYSTEMADMIN_REPOSITORY_WORK_PACKAGE.md

M5A Systemadmin Repository Work Package

Status: **VERIFIED PASS** (2026-08-14) — Code umgesetzt und gemergt (PR #255/#256), beide Owner-Profile mit interaktiv eingerichtetem und verifiziertem nativen TOTP-Faktor, aal2 -Session read-only bestätigt, Advisor ohne unowned HIGH/CRITICAL. Details: docs/evidence/m5a/M5A_VERIFIED_PASS_CLOSURE_EVIDENCE.md . Datum: 2026-08-14 Roadmap phase: M5A Executor: direkte Owner-instruierte Claude-Code-Sitzung (nicht der SA4-Pfad — siehe Korrektur unten) Mandate: .ai/mandates/REM-M5A-REPOSITORY-001.json (bleibt DRAFT ; für diese Umsetzung nicht aktiviert)

Korrektur 2026-08-14

Der ursprünglich vorgesehene Executor (capital-ai-systemadmin-roadmap-executor über den SA4-Pfad) kann dieses Paket strukturell nicht ausführen (Audit-Befund P1-2, siehe docs/evidence/security/SECURITY_AUDIT_2026-08-14_ADR0069_DEVELOPMENT_CHAIN.md). Der Owner hat sich für direkte Implementierung im normalen Branch → PR → Human-Review → CI → Merge-Zyklus entschieden. Die unten stehenden Code-Slices, Exit-Kriterien und Pflichtprüfungen blieben als Spezifikation gültig und wurden vollständig umgesetzt; nur der Ausführungsweg hat sich geändert.

Zweck

Dieses Paket übersetzt den nächsten ausführbaren DEVELOPMENT-CHAIN-Schritt in einen begrenzten, codebasierten Auftrag.

Es autorisiert durch seine Existenz keine Mutation. Aktivierung erfordert:

1. Merge dieses Governance-Pakets;
2. Human/Owner-Akzeptanz von ESS-0020 und ADR-0064;
3. exakte Aktualisierung des Mandats auf dann-current main ;
4. Statuswechsel des Mandats von DRAFT zu OWNER_APPROVED mit Approval-Evidence;
5. SA1/SA2/SA3A/SA3B-Validierung und Permit-before-side-effect.

Zulässiger Auftrag

Der Systemadministrator darf innerhalb des aktivierten REM:

- aktuellen MFA-/Step-up-Code analysieren;
- Native-MFA-Service für Supabase enroll → challenge → verify implementieren;
- zentrale serverseitige AAL2-Prüfung implementieren;
- Owner/Admin-AAL1-, stale- und Auth-Fehlerpfade fail-closed machen;
- bestehende purpose-bound Step-up-Tokens nur oberhalb AAL2 erhalten;

- positive und negative Tests ergänzen;
- redigierte M5A-Evidence erzeugen;
- frischen Branch, Commits und Draft-PR über den auditierten SA-Pfad erstellen;
- nach Human-/Owner-Gate genau einen finalen CI-Lauf anfordern.

Verbotene Operationen

Der Systemadministrator darf in diesem Paket nicht:

- Supabase-Faktoren einschreiben, bestätigen, entfernen oder zurücksetzen;
- TOTP-Secrets, Codes, Factor-IDs, Recovery-Codes oder Tokens lesen/protokollieren;
- Supabase-Projekteinstellungen, Auth-Konfiguration oder Postgres-Schema verändern;
- Legacy-TOTP-/Recovery-Daten löschen;
- Render deployen oder Umgebungsvariablen verändern;
- Stripe, IONOS, Rulesets, Required Checks oder CODEOWNERS verändern;
- den eigenen REM erweitern;
- PRs approven oder mergen.

Code-Slices

Slice A — Authority und Service

- `src/platform/Security/nativeMfa.ts`
- `src/platform/Security/authMiddleware.ts`
- Tests: `tests/unit/nativeMfa.test.ts`, `tests/unit/authMiddlewareAal2.test.ts`

Exit:

- AAL1 für privilegierte Aktionen DENY;
- stale `aal2/aal1` DENY;
- Auth-/AAL-Fehler DENY;
- keine Clientmarker als Authority.

Slice B — Enrollment/Login UI

- `src/components/TotpSettings.tsx`
- `src/components/LoginStepUpGate.tsx`
- Integrationstest: `tests/integration/nativeMfaAal2.test.ts`

Exit:

- supported Supabase native flow;
- unverified factor kein Erfolg;
- Session/AAL nach Verify neu bewertet;
- keine Secret-Ausgabe in Logs/Evidence.

Slice C — Purpose-bound Step-up

- `server/stepUp.ts`
- bestehende `tests/unit/totp.test.ts` nur für Migration/Regression

Exit:

- Step-up ohne AAL2 DENY;
- wrong user/purpose/replay DENY;
- Legacy-TOTP kann keine privilegierte Autorität mehr allein erzeugen;
- Legacy-Recovery bleibt bis separatem Cutover erhalten.

Pflichtprüfungen

Positive:

- native enroll/challenge/verify erreicht AAL2 in kontrolliertem Test;
- AAL2 + IAM-Rolle + erforderlicher Step-up erlaubt ausschließlich die Zielaktion.

Negative:

1. Owner/Admin AAL1;
2. enrolled/unverified factor;
3. falscher TOTP-Code;
4. ungültige/abgelaufene Challenge;
5. fehlender Faktor;
6. stale `aal2/aal1`;
7. Auth-/Netzwerkfehler;
8. Step-up ohne AAL2;
9. falscher User/Purpose;
10. Replay;
11. unauthorized factor reset;
12. unerlaubter Pfad oder REM-Scope-Erweiterung.

Rollback

Repository-Rollback erfolgt durch Human-autorisierte Revert-PR. Legacy-Recovery und bestehende Faktorpfade werden bis zur späteren produktiven Verifikation nicht gelöscht. Ein fehlgeschlagener Code-Cutover darf keine automatische Faktorentfernung auslösen.

Nachgelagerter Produktions-Handoff

Erst nach Repository-CI PASS wird ein separater nicht-autorisierender M5A-Supabase-Handoff vorbereitet. Native Owner-Faktor-Enrollments bleiben interaktive Human-/Owner-Aktionen. Autonome externe Mutation über SA5 bleibt bis M10 `VERIFIED PASS` blockiert.

Definition of Done dieses Work Packages

- REM-Scope eingehalten;
- Code und Tests vollständig;
- alle Pflicht-Negativtests PASS;
- keine Secrets in Diff/Logs/Evidence;
- auditiertes BRANCH → COMMIT → PR;
- Human file review und aktuelle Head-Freigabe;
- CI PASS;
- Human merge;
- Remote-Branch gelöscht;
- M5A bleibt danach bis zur produktiven Owner-Faktor-Verifikation **IN PROGRESS**.

CAPITAL-AI Marketing Agent Roadmap

Quelle: docs/roadmaps/MARKETING_AGENT_ROADMAP.md

CAPITAL-AI Marketing Agent Roadmap

Status: SUPERSEDED (2026-08-15)

Nachfolger (Single Point of Trust): [docs/roadmaps/SEO_G00-](#)

[GLE_MARKETING_CONSOLIDATED_ROADMAP.md](#) — **Document ID: SEO-GM-ROADMAP-0002**

Marketing-Phasen MA0-MA7 sind dort als **WP-M** / WP-N** konsolidiert. ADR-0068 / ESS-0022 bleiben die Entscheidungs-/Vertrags-Authority; diese Roadmap begründet keine parallele Programmautorität mehr.

Status: **SUPERSEDED** — ehemals DRAFT — IMPLEMENTATION NOT AUTHORIZED

Date: 2026-08-12 (historisch) / Supersede: 2026-08-15

Baseline (historisch): [main@3a733f2b6efeffb3013fbb2c558b5ef4c185125e](#)

Owner: SvenKulesa

Logical agent: [capital-ai-marketing-roadmap-executor](#)

Authority draft: ESS-0022 / ADR-0068

Goal (historisch, unverändert als Evidence)

Create a dedicated Marketing Roadmap Executor that can eventually execute bounded Owner-approved SEO, content-generation, media-rendering and marketing-distribution repository work without inheriting Systemadmin authority.

The target operating model remains:

[Owner-approved Marketing Roadmap authority -> domain-limited Marketing Agent -> audited branch/commit/PR work -> Human review/merge -> later separately governed external publication](#).

Fortschreibung und offene Arbeitspakete: ausschließlich **SEO-GM-ROADMAP-0002**.

Hinweis zur weiteren Nutzung

- MA0 Governance-Paket, Capability-States und Plane Separation sind in SEO-GM-ROADMAP-0002 §5-§7 abgebildet.
- Die Execution Policy [docs/governance/MARKETING_AGENT_ROADMAP_EXECUTION_POLICY.md](#) bleibt Draft bis Owner-Acceptance von ADR-0068/ESS-0022 und wird nicht durch diese Datei aktiviert.
- Keine Runtime-Capability wird durch dieses SUPERSEDED-Dokument gewährt.

CAPITAL-AI S1 Security Hardening Roadmap

Quelle: docs/roadmaps/S1_SECURITY_HARDENING_ROADMAP.md

CAPITAL-AI S1 Security Hardening Roadmap

Status: READY FOR OWNER REVIEW Status date: 2026-08-12 Repository baseline reviewed: `main@4767b86d0a183fef97ec812e77da3e5dcbd9d813` Security baseline: `docs/security/SECURITY_REMEDIATION_BASELINE_2026-08-12.md`

Objective

Close the Security Audit 2026-08-12 findings without duplicating work already owned by M5, M5A, M6, M7 and M9. S1 is a bounded security gate inside the existing DEVELOPMENT Chain, not a parallel development program.

Verbindlicher PR-Template-Contract

Jeder Pull Request gegen `main`, einschließlich aller S1-Remediation-PRs, MUSS die vollständige kanonische Vorlage `.github/pull_request_template.md` verwenden.

- kein verkürzter oder frei formulierter PR-Body anstelle der Vorlage;
- alle nummerierten Abschnitte bleiben erhalten;
- nicht zutreffende Felder werden mit `N/A` begründet;
- maschinenlesbare Marker und Human-/Owner-Attestations bleiben wortgleich;
- nach jedem neuen Head wird die Approval-Evidence für den neuen Head erneut erzeugt;
- eine separate Governance-Hardening-Aufgabe ergänzt maschinelle Template-Contract-Validierung aus einer vertrauenswürdigen Baseline;
- kein laufender PR darf durch die von ihm selbst geänderte CI-Authority allein autorisiert werden.

Integration into the DEVELOPMENT Chain

Current canonical chain remains authoritative. For security closure, the intended gate sequence is:

```
M5 / M5A obligations
→ S1 SECURITY HARDENING
→ S1 HIGH-SEVERITY GATE
→ M6 Supply Chain Provenance
→ M7 Deployment Identity
→ M8 Agent Cutover
→ M9 Assurance
→ M10 Owner Passkey Authorization
```

S1 documentation may be prepared while M5/M5A verification is active. S1 code work must follow the repository's sequential work-item rule unless a Human/Owner explicitly classifies a specific finding as an emergency security hotfix.

Every implementation work item uses:

```
current main
→ fresh scoped branch
→ bounded implementation
→ positive + negative tests
→ PR using canonical template
→ Human file review / CI
→ Human merge
→ remote branch deletion
→ evidence + roadmap sync
```

No agent may merge its own remediation PR.

S1.0 — Baseline, ownership and traceability

Type: documentation-only

Deliverables:

- reconcile F-01..F-18 against current code;
- distinguish OPEN , PARTIAL , VERIFIED PASS , ACCEPTED ;
- bind each finding to one owning phase;
- preserve current DEVELOPMENT Chain authorities;
- create docs/evidence/s1/ only when implementation evidence exists.

Exit:

- all 18 findings have an owner and closure criterion;
- no finding is marked closed from roadmap intent alone.

S1.1 — Documentation API authorization and filesystem boundary

Priority: P0 **Findings:** F-01, F-11, F-12

Required implementation:

1. inventory all callers of GET /api/docs-file and POST /api/docs-file ;
2. remove endpoints that are not required at runtime;
3. otherwise enforce verified application identity and explicit role/capability at the route/service boundary;
4. writes require privileged authorization and, where the action is Owner-sensitive, the canonical step-up/AAL2 policy;
5. replace residual deny-list path assumptions with one canonical docs-root containment helper using resolved paths and path.relative() semantics;
6. reject absolute, traversal, encoded traversal, null-byte and out-of-root targets;

7. define symlink behavior explicitly and test it where filesystem semantics permit;
8. add request/body/file-size limits to the write path;
9. emit redacted audit evidence for accepted and denied privileged operations.

Negative tests:

- anonymous GET;
- anonymous POST;
- authenticated but unauthorized role;
- missing required AAL2/step-up;
- `../` , `..\` , absolute, encoded traversal and out-of-root targets;
- oversize body/file;
- attempted `.github` or other non-docs write.

Exit:

- F-01 and F-11 `VERIFIED PASS` ;
- F-12 `VERIFIED PASS` or documented platform-specific residual risk;
- runtime artifact guard is no longer treated as the primary authorization control.

S1.2 — Production runtime controls fail closed

Priority: P0 **Finding:** F-02

Required implementation:

- production-capable execution **MUST** reject `CAPITAL_AI_RUNTIME_ARTIFACT_MODE=off` ;
- missing/invalid security-mode configuration **MUST** not become a healthy production state;
- boot/preflight/readiness exposes an explicit guard state;
- production start or readiness fails before serving traffic when the invariant is violated;
- Docker/Render handoff documentation names the invariant but does not mutate Render directly from development.

Negative tests:

- production + `off` ;
- production + invalid mode;
- missing required runtime security state;
- altered runtime artifact where the guard is expected to protect immutability.

Exit:

- F-02 `VERIFIED PASS` with boot/readiness evidence.

S1.3 — Trusted proxy, client identity and rate limiting

Priority: P0 **Findings:** F-04, F-15

Required implementation:

- identify the exact Render-to-application proxy topology before enabling trust;
- configure an explicit trusted-proxy boundary appropriate to that topology;
- use framework-resolved canonical client IP only after trust policy evaluation;
- never treat raw `X-Forwarded-For` as authenticated identity;
- separate network evidence (`client_ip` , proxy chain/source) from user/session identity;
- bind rate-limit keys to trusted request context;
- determine whether the current in-memory limiter remains valid for the deployed topology;
- before horizontal scaling, replace topology-unsafe local state with a shared/durable limiter or equivalent bounded control.

Negative tests:

- spoofed XFF;
- multiple forwarded values;
- direct connection semantics where applicable;
- rate-limit bypass attempt by rotating spoofed headers;
- audit event must distinguish verified identity from untrusted network metadata.

Exit:

- F-04 `VERIFIED PASS` before M6;
- F-15 may close in S1.3 or remain an explicit M7 blocker if production is provably single-instance and the scale transition is gated.

S1.4 — Server-secret namespace isolation

Priority: P0 **Finding:** F-05

Required implementation:

- inventory all server secret resolvers and environment aliases;
- prohibit fallback from server-only secrets to browser-exposed `VITE_*` names;
- create an explicit allowlist for client-visible configuration;
- add deny rules for known secret-class identifiers (`service role` , private Stripe key, TOTP/encryption keys, metrics/admin tokens and equivalents);
- build-time test verifies client artifacts do not contain server-secret identifiers/values;
- startup validation fails closed for incorrectly namespaced production secrets.

Negative tests:

- only `VITE_*` variant of a required server secret is present;
- secret-like `VITE_*` variable is provided;
- built frontend is scanned for injected server-secret marker values.

Exit:

- F-05 `VERIFIED PASS` before M6.

S1.5 — CI trust-chain and GitHub output integrity

Priority: P0/P1 **Findings:** F-03, F-09

M3 controls are retained, not replaced. This slice validates their residual trust boundary.

Required implementation:

- preserve Owner gate, exact PR head-SHA freshness and trusted-main policy retrieval;
- add an independent invariant validator for changes under `.github/workflows/**`, `.github/actions/**` and CI policy code;
- validator checks that required jobs/dependencies cannot be removed or weakened by the PR being evaluated;
- fail on privilege widening, unsafe event-model changes such as unapproved `pull_request_target`, unsafe credential persistence, or replacement of trusted-main policy with PR-controlled policy;
- use safe GitHub output serialization; untrusted multiline values cannot create additional output keys or workflow commands;
- keep actions pinned and least-privilege; complete provenance/version consolidation in M6 rather than duplicating it here;
- add machine validation that PR bodies retain the canonical `.github/pull_request_template.md` contract, implemented from a trusted baseline rather than PR-controlled policy.

Negative tests:

- PR deletes/bypasses `ci-gate` dependency;
- PR weakens Owner/head-SHA gate;
- PR attempts output injection with newline/delimiter payload;
- PR widens workflow token permissions;
- PR changes event model to a more privileged trigger without explicit allowed invariant;
- PR removes/renames mandatory template sections or Human-/Owner attestations.

Exit:

- F-03 and F-09 `VERIFIED PASS` ;
- M3 remains the CI authority, S1 only closes the identified residual weakness;

- canonical PR-template usage is machine-validated from trusted policy.

S1.6 — Browser HTTP policy hardening

Priority: P1 **Findings:** F-06, F-07, F-08

Required implementation:

1. inventory every active CSP/CORS implementation;
2. converge to one authoritative CSP generator/middleware;
3. remove obsolete/duplicated CSP paths;
4. eliminate `unsafe-eval` unless a documented, tested dependency makes it temporarily unavoidable;
5. minimize `connect-src`, `form-action`, frame and script authorities to actual production needs;
6. dynamic CORS responses emit `Vary: Origin` correctly;
7. untrusted origins fail closed;
8. verify Stripe/cookie/analytics/frontend integrations against the policy before strict promotion.

Promotion path:

```
inventory
→ report evidence where necessary
→ integration tests
→ enforced policy
→ M9 adversarial assurance
```

Exit:

- F-06, F-07 and F-08 `VERIFIED PASS` before final M9 closure.

Existing phase ownership — do not duplicate

M5 Audit / Telemetry

Owns F-16. Replace weak/reversible token correlation with a non-secret, non-reversible stable correlation strategy and prove redaction/audit completeness.

M5A Native MFA / AAL2

Owns F-14. Closure requires current replay-negative evidence and authoritative AAL2 semantics; a completed implementation without replay evidence is not sufficient.

M6 Supply Chain Provenance

Owns F-10 and the remaining F-17 work: source identity, runtime/action pinning, SBOM, provenance, attestations and immutable artifact identity.

M7 Deployment Identity

Owns deployment/runtime identity and any topology transition that makes F-15 require a distributed limiter. It also consumes, but does not replace, S1.2 fail-closed runtime-control evidence.

M9 Assurance

Owns independent/adversarial re-verification and F-13 constant-time metrics/admin token comparison. M9 must rerun relevant S1 bypass, injection, replay and exfiltration tests.

F-18

Retain `ACCEPTED` / `INTENTIONAL` only when evidence proves deny-by-default RLS is the intended contract and no service path relies on unintended access. Do not add a permissive RLS policy solely to close an informational finding.

PR slicing

Use small reviewable PRs; do not combine unrelated trust boundaries. Every PR uses the canonical template completely.

PR	Scope	Findings	Class
S1-DOC	baseline + roadmap only	F-01..F-18	documentation
S1-01	docs API authorization/filesystem	F-01/F-11/F-12	security code
S1-02	runtime fail-closed	F-02	security code
S1-03	proxy/IP/rate limit	F-04/F-15	security code
S1-04	secret namespace	F-05	security code
S1-05	CI trust/output/template integrity	F-03/F-09 + PR template contract	CI/security
S1-06	CSP/CORS	F-06/F-07/F-08	HTTP security
existing	M5/M5A/M6/M9 work	F-10/F-13/F-14/F-16/F-17/F-18	canonical phases

After each merged PR, delete its remote work branch and start the next item from then-current `main`.

S1 High-Severity Gate

M6 implementation is blocked until:

```
F-01 VERIFIED PASS
AND F-02 VERIFIED PASS
AND F-03 VERIFIED PASS
AND F-04 VERIFIED PASS
AND F-05 VERIFIED PASS
```

Additionally:

- F-11 must close together with S1.1;
- any unresolved Medium/Low finding must have an explicit later-phase owner and blocking criterion;
- no `VERIFY + REMEDIATE` finding may be silently converted to `PASS` without code/test evidence.

Definition of Done

S1 is complete only when:

- all five High findings are `VERIFIED PASS` ;
- F-11 and F-12 are closed or an explicit bounded residual risk is Owner-accepted;
- F-06..F-09 have implementation/test evidence or are explicitly gated before M9;
- canonical later phases retain F-10/F-13/F-14/F-16/F-17/F-18 ownership;
- no secrets are present in evidence;
- all remediation PRs use the complete canonical PR template;
- all remediation PRs received Human review and Human merge;
- work branches are deleted after successful merge;
- DEVELOPMENT Chain roadmap and traceability are synchronized to the exact final SHAs.

Screening · Scoring · Market Data — Single Point of Trust Roadmap

Quelle: docs/roadmaps/SCREENING_SCORING_MARKET_DATA_SPT_ROADMAP.md

Screening · Scoring · Market Data — Single Point of Trust Roadmap

Document ID: SC-MD-SPT-0001
Version: 1.0.4
Status: ACTIVE — CANONICAL EXECUTION AUTHORITY
Stand: 2026-08-16
Repository-Baseline: `main` (SC-1 / SC-3 / SC-4 Phase A / SC-7 Phase A+B; SC-5 Phase A landed, Phase B in flight)
Owner: SvenKulesa
Authority: DOCUMENTATION_HYGIENE_POLICY · ROAD-MAP_CONSOLIDATION_MASTER_INDEX · ADR-0020 / ADR-0041 · ESS EventMesh/Traceability

1. Zweck

Dieses Dokument ist der **Single Point of Trust (SPT)** für die Screening-/Scoring-/Market-Data-Wertschöpfungskette der CAPITAL-AI Multi-Asset-Plattform (8 Assetklassen, Universal-Asset-Interface-Ziel, Score-Kontrakte, Market-Data-Gateways).

Es ersetzt als Ausführungsautorität:

Dokument	Rolle	Status nach diesem SPT
docs/architecture/ENTERPRISE_SCREENING_SCORING_MASTER_ARCHITECTURE.md (Phase 2)	Aspirational Blueprint Aug-01	SUPERSEDED — Phase-1-Inventar bleibt Evidence
docs/architecture/ENTERPRISE_SCREENING_REMEDIATION_2026-08.md	Enger Remediation-Scope	ARCHIVED → docs/archive/legacy/
Parallel-Remediation-Branches / Ad-hoc-Screening-Todos	Fragmentiert	FORBIDDEN — nur über dieses SPT

Keine parallele Remediation. Alle offenen Screening-/Scoring-/MD-Arbeiten werden ausschließlich hier getrackt.

2. Code-vs-Docs-Synthese (Update 2026-08-16)

2.1 Was der Code heute liefert

Schicht	Code-Pfad	Reife
Market-Data Gateway	<code>src/platform/MarketData/</code>	SC-4 Matrix/Health + SC-5 Coin-Gecko price + multi-field matrix guards
Provider	TwelveData, FMP Index, CoinGecko (price + matrix-aligned multi-field); Alpaca shadow	Kern live
Evidence / Consensus	Snapshot/Spot consensus, traditional/commodity/macro evidence	Stark ausgebaut
Scoring-Engines	Base/DeFi, crypto 9-Faktor, meme, raw materials, traditional, verified technical	Multi-Engine, noch fragmen-tiert
Ranking / Eligibility	<code>ranking.service</code> + SC-7 composite opt-in (Phase A+B)	Crypto-lastig; orchestrator wi-red
Classification	Adapter + expanded deterministic table (SC-1)	Canonical exit path
Unified DQ/Confidence	<code>CompositeDataQuality</code> (SC-3); impact flags false	Foundation + ranking consumer map

2.2 Verbleibende Lücken

1. scoreImpact / rankingImpact noch Owner-gated (false)
2. Ranking-Generalisierung cross-asset (Overall / Category / Tier / Growth)
3. Canonical multi-field crypto snapshot on gateway + execution-price quorum (SC-5 Phase C+)
4. Model registry & UAI adapters (SC-2)
5. Alpaca primary promotion (ADR-0041 Owner gate)
6. Horizon / Walk-Forward backtests (SC-8)

3. Kanonische Wertschöpfungskette (SPT-Modell)

```

[Providers] → MarketDataGateway (CB/Cache/RL/Coalesce + ProviderMatrix)
      ↓
DataQualityService + Evidence/Consensus Services
      ↓
Classification (Asset Class / Category / Tier)
      ↓
Scoring Engines (per class / model registry)
      ↓
Confidence + DQ Composite → Ranking / Eligibility / SLO
      ↓
EventMesh (score.* / data.*) + Traceability + Supervisor
      ↓
API / Screener UI / Alerts / Backtest Evidence

```

Harter Vertrag: Universal Asset Interface (Adapter), Score-Kontrakt, fail-closed Evidence, keine Symbol-Hash-/Random-Walk-Finanzlogik.

4. Ausführungs-Backlog (SC-*)

ID	Titel	Priorität	Status (2026-08-16)	DoD (kurz)
SC-0	Baseline freeze & inventory	P0	LANDED	SPT gemerged
SC-1	Classification consolidation	P0	LANDED	Canonical schema; deterministic coverage
SC-2	Model registry & UAI adapters	P1	OPEN	model_registry; UAI adapters
SC-3	Unified DQ + Confidence composite	P0	FOUNDATION LANDED	Composite; impact off
SC-4	Gateway hardening & provider matrix	P1	Phase A LANDED	Matrix + RL + supervisor health
SC-5	Live coverage expansion	P1	Phase A LANDED; Phase B (matrix multi-field) in flight	Canonical market fields + execution quorum still open
SC-6	Scoring integrity & lineage	P1	PARTIAL	calculation_version + lineage
SC-7	Ranking generalization	P1	Phase A+B LANDED	Cross-asset modes still open; impact off
SC-8	Horizon / Walk-Forward backtests	P2	OPEN	Drift-Evidence; golden-set regression

Kritischer Pfad: SC-0 → SC-1 + SC-3 → SC-4 → SC-5 → SC-2/SC-6 → SC-7 (full) → SC-8.

5. Authority & Mutationsregeln

1. Runtime-/Code-/Produktions-Evidence
2. Explizite Human/Owner-Freigabe
3. Spezifische ADR/ESS (Market Data: ADR-0020, ADR-0041; Screening-SLO: ADR-0028)
4. **Dieses SPT (SC-MD-SPT-0001)**
5. ROADMAP_CONSOLIDATION_MASTER_INDEX
6. Historische/archivierte Docs

Mutation von Scoring-Gewichten, Eligibility-Schwellen, Provider-Routing, Live-Gates oder **scoreImpact/rankingImpact** erfordert Owner-Freigabe.

6. Related

- `docs/roadmaps/work-packages/SC-1_CLASSIFICATION_CONSOLIDATION.md`
- `docs/roadmaps/work-packages/SC-3_UNIFIED_DQ_CONFIDENCE.md`
- `docs/roadmaps/work-packages/SC-4_GATEWAY_HARDENING_PROVIDER_MATRIX.md`
- `docs/roadmaps/work-packages/SC-5_LIVE_COVERAGE_EXPANSION.md`
- `docs/roadmaps/work-packages/SC-7_RANKING_COMPOSITE_OPT_IN.md`
- `docs/evidence/sc-md/`
- `src/platform/MarketData/ProviderMatrix.ts`
- `src/platform/MarketData/providers/CoinGeckoMarketDataProvider.ts`
- `src/services/cryptoQuoteEvidence.ts`
- `src/services/cryptoSnapshotProvider.ts`

SC-5 Phase B 2026-08-16 (matrix multi-field guards). Keine scoreImpact-Mutation. Keine Alpaca-Promotion. Merge nur nach Owner-Review.

CAPITAL-AI SEO + Google Marketing — Konsolidierte Programm-Roadmap

Quelle: docs/roadmaps/SEO_GOOGLE_MARKETING_CONSOLIDATED_ROADMAP.md

CAPITAL-AI SEO + Google Marketing — Konsolidierte Programm-Roadmap

Document ID

SEO-GM-ROADMAP-0002

Status

ACTIVE — CANONICAL EXECUTION AUTHORITY (Domain SEO / Google Marketing / Content Distribution)

Stand: 2026-08-16

Baseline: `main` (ADR-0082; WP-S1 VERIFIED; WP-D3 Soft-404 VERIFIED PR #360; **Q3 Search Console Domain property VERIFIED; WP-D1/D2 VERIFIED** PR #375 + Owner Rich Results Test)

Owner: SvenKulesa

Authority-Bindung: ADR-0035, ADR-0042, ADR-0068 (PROPOSED), ADR-0082 (SeoEngine), ESS-0014, ESS-0022 (PROPOSED), ADR-0071, ESS-0023

Zweck

Dieses Dokument ist der **Single Point of Trust** für alle noch offenen und laufenden Arbeiten zu:

- Technical SEO und SEO-Management (SeoEngine)
- Google Analytics / Search Console / Consent Mode v2 / AdSense
- Google Marketing MCP (Read-Plane vs. kontrollierte Write-Plane)
- Content-Generierung, Media-Rendering und Social Distribution
- Marketing-Agent-Governance (getrennt vom Systemadmin)
- Monetarisierung (passives Einkommen) innerhalb bestehender Consent-/OWNER-Gates

Es **löst** die parallelen, teilweise überlappenden Roadmaps und Teilspezifikationen ab, um:

1. Wucherung und Unstimmigkeiten zu beenden,
2. doppelte Architekturentscheidungen (SEO vs. Marketing vs. Google MCP) zu vermeiden,
3. alle unerledigten Arbeitspakete auf einen aktuellen, evidence-gebundenen Stand zu bringen,
4. klare Anschlüsse an Documentary, Vocabulary (Wiktionary-Äquivalent), VersionManager und die übrige Plattformarchitektur zu definieren.

Keine Mutationsberechtigung entsteht durch dieses Dokument allein. Runtime-, Produktions-, Billing-, AdSense-, DNS- und externe Publish-Änderungen bleiben OWNER-genehmigungspflichtig (ADR-0035, ADR-0039, ESS-0014).

1. Supersedes (verbindliche Ablösung)

Die folgenden Dokumente gelten ab Merge dieses Standes als **SUPERSEDED** für Programmautorität und offene Arbeitspakete. Historischer Evidence-Wert bleibt erhalten; sie dürfen keine parallele Architektur mehr begründen.

Altes Dokument	Document ID / Rolle	Nachfolger
docs/seo/SEO_MANAGEMENT_ROADMAP.md	SEO-ROADMAP-0001	dieses Dokument
docs/roadmaps/MARKETING_AGENT_ROADMAP.md	MA-Roadmap (DRAFT)	dieses Dokument (Abschnitt MA → WP-M)
docs/seo/S1_SEO_ENGINE.md ... S4 ... (als Programmplan)	Block-Specs	eingearbeitet; Specs bleiben technische Evidence
docs/seo/Q_BLOCK_IMPLEMENTATION_NOTES.md , D_BLOCK_...	Implementation Notes	Status in §4; Notes bleiben Evidence
docs/adr/ADR-DRAFT-seo-engine-platform-module.md	Draft	ADR-0082 (docs/adr/ADR-0082-seo-engine-platform-module.md)
docs/adr/ADR-DRAFT-prerender-public-routes.md	Draft	zu formalisieren unter WP-S2
Parallele Aussagen in Architektur-MCP-Docs, soweit sie offene Programmarbeit duplizieren	—	ESS-0014 + dieses Dokument sind normativ für den Programmplan

Nicht supersediert (bleiben Authority):

- ADR-0035 (Protected Google Marketing / Strict CSP)
- ADR-0042 (Consent Mode v2)
- ESS-0014 / ESS-0014-CONTRACTS (Google Marketing MCP Governance)
- ADR-0026 / ADR-0027 (Social Publishing Real Integration + Owner Restriction)
- Bestehende SocialMediaEngine-Code- und OAuth-Boundaries
- ROADMAP_CONSOLIDATION_MASTER_INDEX.md (Portfolio-Ebene; wird auf dieses Programm umgestellt)

2. Authority-Reihenfolge (Domain)

1. Verifizierte Runtime-/Production-Evidence und Code auf `main`
2. Ausdrückliche Human/Owner-Freigabe (ADR-0039, Protected Change ADR-0035)

- 3. ESS-0014, ADR-0035, ADR-0042, ADR-0082 und akzeptierte ADRs dieses Programms
- 4. **Dieses Dokument (SEO-GM-ROADMAP-0002)**
- 5. Fachliche Block-Notes und Runbooks unter docs/seo/ , docs/runbooks/
- 6. Historische / als SUPERSEDED markierte Roadmaps

Bei Widerspruch gilt die restriktivere, aktuellere und spezifischere Regel. Agent-Identität (Marketing vs. Systemadmin) erzeugt keine Authority-Überschneidung (ADR-0068 / ESS-0022).

3. Zielbild (einheitlich)

Mission. Ein vollständiges Capital-AI SEO- und Google-Marketing-Management, das:

- messbare Indexierung und Rankings liefert (No-Demo-Data),
- Consent Mode v2 und Strict CSP einhält,
- Content plant/generiert und nur nach hash-gebundener Owner-Freigabe verteilt,
- Social-Plattformen über die **eigene** SocialMediaEngine anbindet (Open-Source-Tools nur als optionale Adapter/Evidence, nie als Authority),
- Monetarisierung (AdSense, Affiliate, Subscriptions) hinter Consent- und OWNER-Gates ermöglicht (passives Einkommen),
- an Documentary (Provenance), Vocabulary Registry und VersionManager angeschlossen ist.

Nicht-Ziele.

- Kein paralleles zweites Publishing-System neben SocialMediaEngine
- Kein LLM-direkter Publish ohne Trust-/Approval-Plane
- Keine Systemadmin-Authority für Marketing-Domain
- Keine synthetischen Rankings oder Fake-Finanzkennzahlen

4. Ist-Stand (Evidence, 2026-08-16)

4.1 Technical SEO / SeoEngine

WP	Status	Evidence
Q1 robots.txt + sitemap	DONE	public/robots.txt , public/sitemap.xml
Q2 canonical + trailing slash	PARTIAL	Canonical in index.html ; Server trailing-slash 301 live (/impressum/ → /impressum); full Q-CLOSE still open
Q3 Search Console Verify	VERIFIED	Domain property capital-ai.on-line ; Ownership bestätigt (Owner

WP	Status	Evidence
		2026-08-16); Sitemap <code>site-map.xml</code> Success in GSC; Claim + Runbook
Q4 Checklist	DONE	<code>docs/seo/SEO_CHECKLIST.md</code>
Q5 og:image first-party	DONE	<code>public/og-image.svg</code>
Q6 obsolete CORS	N/A	Keine AI-Studio-Ausnahme im Tree
D1 JSON-LD	VERIFIED	PR #375; ImageObject logo + SoftwareApplication offers / image ; Owner Rich Results Test success (3 Legal-Unterseiten, 2026-08-16); prod live
D2 route-specific titles/meta	VERIFIED	PR #375; <code>routeSeo + main.tsx</code> load/popstate; prerender; unique titles live / /impressum / agb /datenschutz
D3 Soft-404	VERIFIED	PR #360; prod commit <code>54c48ca</code> ; unknown → 404 text/plain ; evidence <code>docs/evidence/seo/D3_SOFT_404_PROD_GAP_2026-08-16.md</code>
D4 Bundle-Splitting	offen (carried)	—
D5 Search Console MCP Read	offen	Runbook vorhanden; nach Q3
S1 SeoEngine Platform	VERIFIED	Store + Routes + Tests (PR #335); Schema/Grants/FK/Ledger applied 2026-08-15; ADR-0082 Accepted 2026-08-16
S2 Prerender/SSG	offen	ADR-DRAFT vorhanden; partial prerender script live
S3 SEO Dashboard	DONE	PR #309, Admin-Tab, No-Demo-Data
S4 hreflang / Sprache	IN PROGRESS / Branch	Spec <code>S4_LANGUAGE_AND_HREFLANG_STRATEGY.md</code>

4.2 Google Marketing / Consent / CSP

Thema	Status
Consent Mode v2 Gate	ADR-0042 ACCEPTED; Runtime-Consent-JS vorhanden
Protected Marketing + Strict CSP + Nonce	ADR-0035 ACCEPTED, Implementation IN PROGRESS (DoD noch nicht erfüllt)
ESS-0014 Read vs Write Plane	Published; Write-Plane noch nicht produktiv
GA4 MCP Read	Runbook + Work-Claim; begrenzte Read-Integration
AdSense	Architektur/Protected Scope; Smoke/DoD offen

4.3 Social / Content / Marketing Agent

Thema	Status
OAuth PKCE + Token Store + Publish X/Facebook	produktiv (Owner/Founder)
YouTube/TikTok/Instagram	blockiert bis Media-Asset (<code>mediaRequiredError</code>)
<code>generateSeries</code> / Content-API	fehlt (explizit in Code dokumentiert)
Marketing Agent MA0-MA7	DRAFT , keine Runtime-Capability
ADR-0068 / ESS-0022	PROPOSED / DRAFT

5. Einheitliche Arbeitspakete (Work Packages)

Präfixe bleiben kompatibel zur etablierten Q/D/S/N/H/J-Konvention; Marketing-Phasen werden als **WP-M*** parallel geführt, ohne zweite Architektur.

5.1 Fundament & Messbarkeit (Fortsetzung Q/D)

ID	Inhalt	Abhängigkeit	DoD (kurz)
WP-Q-CLOSE	Q2 Server-Trailing-Slash, Q3 Owner-Verify + Site-map-Submit	Owner	Server-301 live; Q3 VERIFIED (Domain <code>capital-ai.online</code> , Sitemap Success 2026-08-16)
WP-D1	JSON-LD Organization/ WebSite/SoftwareApplication	Q	VERIFIED — PR #375; Owner Rich Results Test 2026-08-16
WP-D2	Routen-spezifische Title/ Meta (Legal + Feature)	Q	VERIFIED — unique titles public routes + client sync (PR #375)
WP-D3	Soft-404: unbekannte Routen → HTTP 404	—	VERIFIED — PR #360; prod unknown → 404 <code>text/plain</code> (2026-08-16)
WP-D4	Bundle-Splitting / CWV	—	Messbare LCP/JS-Verbesserung
WP-D5	Search Console als MCP-Read (Evidence)	ESS-0014, Q3	Read-only MCP, kein Write

5.2 SEO-Management-Kern (S)

ID	Inhalt	Abhängigkeit	DoD
WP-S1	SeoEngine Persistenz + RLS + No-Demo-Data	Migration, Security Review	VERIFIED — Ranks nur search-console manual-import; Code DONE (PR #335); Schema/Grants/FK/Ledger applied 2026-08-15; ADR-0082 Accepted 2026-08-16

ID	Inhalt	Abhängigkeit	DoD
WP-S2	Prerender/SSG öffentlicher Routen	ADR formal	Crawler sehen Inhalt ohne JS
WP-S3	Dashboard	DONE	—
WP-S4	hreflang + Sprachstrategie	Vocabulary	Konsistente lang /hreflang

5.3 Content, Media, Distribution (N + MA)

ID	Inhalt	Abhängigkeit	DoD
WP-M0	Governance-Paket: ESS-0022, ADR-0068, Policy, Traceability, inaktives Profil	Human Review	Dokumente accepted; keine Runtime-Capability
WP-N1	POST /api/social-media/generate + Prompt-Orchestrierung	M0, bestehende Types	Text-Packages ohne Publish
WP-N2	Skript-Vorlagen (Tweet, Community, Podcast, Short-Video)	N1	Template-Registry + Tests
WP-N3	Media-Rendering (TTS/Video) als ersetzbarer Si-decar-Adapter	N1, Make-or-Buy Owner	YouTube/TikTok/IG freigeschaltet nur mit validiertem Asset-Hash
WP-N4	Content-Kalender + hashgebundene Owner-Freigabe	N1	Kein Publish ohne Approval-Hash
WP-M5	Erster bounded Marketing-Repo-Pilot (Docs/Contracts)	SA Host VERIFIED + M0	Audit-before-side-effect, Human Merge
WP-M6	Controlled External Publishing Architecture	N4, starke Owner-Approval	Default CONTENT_AUTO_PUBLISH_ENABLED=false
WP-H1	Weitere Plattformen (LinkedIn, ...) über SocialMediaEngine	M6	Kein zweites Token-System
WP-H2	Google Admin/Write nur hinter ESS-0014 Gateway	ADR-0035 DoD	OWNER + Step-up
WP-H3	Feedback-Loop GSC/GA4 → ContentPerformanceScore	D5, S1	Empfehlungen, kein Self-Publish

5.4 Autonomie & Monetarisierung (J + Revenue)

ID	Inhalt	Abhängigkeit	DoD
WP-J1		M5	Least Privilege, Kill Switch

ID	Inhalt	Abhängigkeit	DoD
	Marketing-Agent im Multi-Agent-Framework (eigene Subject-ID)		
WP-J2	Closed Loop mit harter Owner-Schranke	H3, M6	Keine Autonomie ohne Freigabe-Klasse-ADR
WP-R1	AdSense unter Protected Scope + Consent	ADR-0035 DoD	Smoke ohne CSP-Block; Consent-gated
WP-R2	Affiliate-Links in Content-Packages (Disclosure)	N4	Compliance-Disclosure Pflicht
WP-R3	Stripe-Subscriptions (bestehend) als Conversion-Ziel in SEO-Content	Entitlements ADR-0034	Keine Preis-Mutation ohne Billing-ADR

6. Architektur-Anschlüsse (verbindlich)

6.1 Documentary

- Jede generierte ContentPackage und jedes Rank-Snapshot-Event erhält Documentary-Provenance (Quelle, Modell, Template-Hash, Approval-Hash).
- SEO-Programm-Status und Evidence-Dateien folgen Documentary D0-D7 Lifecycle, sobald D0 Baseline stabil ist.
- Kein Marketing-Claim ohne nachvollziehbare Documentary-Linie.

6.2 Vocabulary / „Wiktionary“

- Kanonische SEO-/Marketing-Terme (Keyword, Rank Snapshot, ContentPackage, hreflang, Consent Gate, ...) werden über Vocabulary Governance (ESS-0017 / ADR-0044/0046) registriert.
- UI- und API-Bezeichner folgen der bilingualen Registry; keine Ad-hoc-Synonyme in neuen Modulen.

6.3 VersionManager

- Schema-Migrationen (`seo_*`), Feature-Flags und Release-Gates laufen über VersionManager / Release-Lifecycle (ESS-0004, ADR-0030 resolved).
- Roadmap-Version dieses Dokuments und Schema-Versionen sind in Release-Changelogs referenzierbar.

6.4 SocialMediaEngine & SeoEngine

- **Eine** Distribution-Authority: `SocialMediaEngine` + bestehende Publisher.
- **Eine** SEO-Management-Authority: `src/platform/SeoEngine/` (ADR-0082).
- Open-Source (z. B. rank-tracker-ähnliche Tools, Postiz-ähnliche Orchestratoren, n8n): nur als **optionale Evidence-/Worker-Adapter** hinter CAPITAL-AI-Contracts; niemals OAuth-, Token- oder Policy-Root.

6.5 Google MCP

- Read/Evidence: GA4, Search Console (geplant) gemäß ESS-0014.
- Write/Admin: nur CAPITAL-AI-Adapter + IAM + Approval + Audit; Claude/andere Modelle sind Host-Profile, nicht Trust Root (ADR-0035).

7. Sicherheits- und Governance-Invarianten (unverhandelbar)

1. AI-Provider ist nie Trust Root.
2. Marketing-Agent erbt **keine** Systemadmin-Authority.
3. Consent Mode v2 und Strict CSP+Nonce bleiben geschützt (Protected Change).
4. Quantitative Finanzaussagen brauchen Source-Evidence; sonst DENY für Publish.
5. Human/Owner-Approval ist hash-gebunden bis eine spätere ADR eine sichere autonome Klasse definiert.
6. Merge bleibt Human-only.
7. Shared Integration Zone (Workflows, global IAM, Bootstrap, shared Migrations) erfordert explizite Koordination / Single-Writer.
8. No-Demo-Data: keine geschätzten Rankings in Produktion.

8. Open-Source- und externe Tools (Policy)

Kategorie	Erlaubt als	Nicht erlaubt
Rank-/SERP-Evidence	Read-Adapter hinter SeoEngine	Autoritative Ranking-Quelle ohne GSC/Manual
Social Orchestration (Postiz-ähnlich)	Optionaler Worker hinter SocialMediaEngine	Eigenes Token-Store / Parallel-Publish
Workflow (n8n o. ä.)	Interne Orchestrierung in Sandbox	Produktions-Secrets im Worker
Media (TTS/Video OSS)	Sidecar mit validiertem Input/Output-Hash	Direktzugriff auf Social OAuth

Auswahl und Einführung jedes Adapters: eigener kleiner ADR-Nachtrag + Supply-Chain-Check (M6-Provenance-Prinzipien).

9. Traceability & Definition of Done (Programm)

Pro WP mindestens:

- Verweis auf dieses Roadmap-ID + WP-ID
- ADR/ESS falls Architektur/Trust-Boundary
- Tests (positiv + negativ)
- redigierte Evidence unter docs/evidence/ oder SEO-Notes

- Aktualisierung der Marketing/SEO Traceability Matrix
- PR mit Human Review; Branch löschen nach Merge

Programm gilt als abgeschlossen, wenn:

- alle WP-Q/D/S mit VERIFIED oder OWNER-ACCEPT,
- N1-N4 und M0-M6 mit akzeptierter Governance und mindestens einem bounded Pilot,
- ADR-0035 DoD erfüllt oder explizit risikobegründet akzeptiert,
- keine parallele offene SEO-/Marketing-Roadmap mehr Authority beansprucht,
- Master-Index auf SEO-GM-ROADMAP-0002 zeigt.

10. Sofortige nächste Schritte (Stand 2026-08-16, nach WP-D1/D2 VERIFIED)

1. ~~**Owner:** FK RESTRICT Apply (20260815220000) + Ledger-Abgleich~~ — angewendet 2026-08-15.
2. ~~**Owner:** Search Console Property verifizieren (WP-Q-CLOSE / Q3)~~ — **VERIFIED** 2026-08-16 (Domain `capital-ai.online`, Ownership bestätigt, Sitemap Success).
3. ~~ADR-Draft SeoEngine nummerieren~~ — **ADR-0082** Accepted (Kollisionscheck nach PR #345: 0075-0081 belegt).
4. ADR-0068 + ESS-0022 Owner-Review (WP-M0) — ohne Runtime-Enablement.
5. ~~WP-D3 Soft-404~~ — **VERIFIED** (PR #360; prod curl 2026-08-16).
6. ~~**WP-D1 / D2**~~ — **VERIFIED** (PR #375 merged; prod unique titles; Owner Rich Results Test success for Legal-Unterseiten 2026-08-16).
7. WP-S2 nur nach formalem Prerender-ADR.
8. Optional: **WP-D5** Search Console MCP Read (Credentials Owner-separat).

Vollständiger Übergabekontext: `docs/seo/HANDOFF_WP_S1_NEXT_2026-08-15.md` . Canonical ADR: `docs/adr/ADR-0082-seo-engine-platform-module.md` . Q3 Runbook: `docs/seo/Q3_SEA-RCH_CONSOLE_VERIFY_RUNBOOK.md` .

11. Änderungshistorie

Version	Datum	Änderung
0002.0	2026-08-15	Erstausgabe: Konsolidierung SEO-ROADMAP-0001 + MARKETING_AGENT_ROADMAP + Google-Marketing-Programmplan zu Single Point of Trust
0002.1	2026-08-15	Ist-Stand S1: Store-Code PR #335 auf main; Owner-Gates (FK/Ledger/ADR) explizit; nächste Schritte aktualisiert

Version	Datum	Änderung
0002.2	2026-08-16	WP-S1 VERIFIED : ADR-0082 Accepted (nach PR #345 Nummernraum); §4/§5.2/§10 synchronisiert
0002.3	2026-08-16	WP-D3 Soft-404 VERIFIED (PR #360; prod commit 54c48ca ; unknown → 404); §4/§5.1/§10 synchronisiert
0002.4	2026-08-16	Q3 / WP-Q-CLOSE Search Console Domain property VERIFIED (Owner: capital-ai.online Ownership bestätigt; Sitemap Success); §4/§5.1/§10 + Checklist/Runbook/Claim synchronisiert
0002.5	2026-08-16	WP-D1 / D2 CODE READY — JSON-LD ImageObject + offers; routeSeo client popstate + unit test; §4/§5.1/§10 + Checklist/Claim
0002.6	2026-08-16	WP-D1 / D2 VERIFIED — PR #375; Owner Rich Results Test success (3 Legal-Unterseiten); Claim + Checklist + §4/§5.1/§10

CAPITAL-AI Systemadmin Agent Roadmap

Quelle: docs/roadmaps/SYSTEMADMIN_AGENT_ROADMAP.md

CAPITAL-AI Systemadmin Agent Roadmap

Status: IMPLEMENTATION PHASE Date: 2026-08-14 Current repository baseline: `main@66da35b80ba23e4f216318a9cd9f9b4e7b787679` (PR #255 merge) Authority: ESS-0021, ADR-0065, ADR-0058, ADR-0059, ADR-0066, ADR-0067, ADR-0068

Sync 2026-08-14: SA0-SA4 bleiben `COMPLETE / VERIFIED PASS` ; keine Statusänderung durch PR #255 (M5A wurde direkt implementiert, nicht über den SA4-Pfad — siehe Korrektur im M5A-Abschnitt unten und `docs/roadmaps/DEVELOPMENT_CHAIN_ROADMAP.md`). SA5 bleibt bis M10 `VERIFIED PASS` blockiert.

Reaktivierung 2026-08-14 (Owner-Anweisung "aktiviere bitte sa3b und sa4 wieder"): SA3B-Trigger wurde reaktiviert (`.github/workflows/systemadmin-roadmap-executor.yml`) — nutzt weiterhin exakt das bestehende `OWNER_APPROVED` -Mandat `REM-SA3B-PROBE-001` , keine neue Aufgabe. SA4 bleibt bewusst deaktiviert: `scripts/systemadmin/runSa4Pilot.mjs` ist kein generisches Ausführungsskript, sondern fest an sein bereits gemergtes Zielartefakt (`docs/evidence/sa4/SA4_FIRST_AUTONOMOUS_WORK_PACKAGE.md`) inklusive fest codiertem Inhalt gebunden — ein reiner Trigger-Flip würde sofort am Self-Blocking-Check scheitern. Eine neue SA4-Aufgabe braucht ein neues Pilot-Skript und ein neues Mandat, was gemäß Owner-Entscheidung erst nach M5A `VERIFIED PASS` mit einem konkret auf Dateiebene feststehenden M6-Arbeitspaket sinnvoll angegangen wird.

Goal

The Systemadmin Roadmap Executor may autonomously implement Owner-approved repository work packages only through bounded REM authority, least privilege, durable append-only audit evidence, Human final review and Human-only merge.

Stage status

Stage	Status	Core evidence
SA0 Governance	COMPLETE	PR #214
SA1 REM Validator	COMPLETE / VERIFIED PASS	PR #215
SA2 Chat Execution Profile	COMPLETE / VERIFIED PASS	PR #216
SA3A Append-only Audit Adapter	COMPLETE / VERIFIED PASS	PR #218
SA3B Execution Host	COMPLETE / VERIFIED PASS — trigger reaktiviert 2026-08-14 (Owner-Anweisung), gleiches Mandat	PR #220, #222; Issues #221/#223/#224; lifecycle cleanup verified before SA4
SA4 First bounded autonomous work package	COMPLETE / VERIFIED PASS — trigger bleibt bewusst deaktiviert, siehe Korrektur 2026-08-14 unten	PR #226; Issue #228 / run <code>31579519025</code> ; PR #229; six M5 authorization/outcome events

Stage	Status	Core evidence
SA5 Bounded external mutation design	BLOCKED	M10 VERIFIED PASS required

M10 passkey-only PR authorization target architecture was merged in PR #217, but runtime cutover remains sequentially blocked by M9. Until that cutover, current Human/Owner current-head review and attestation remain authoritative for final CI and merge.

SA0 — Governance

COMPLETE — PR #214 MERGED

REM schema, ESS/ADR authority and branch lifecycle are on `main`.

SA1 — REM validator / Control Plane

COMPLETE / VERIFIED PASS — PR #215 MERGED

Capability ceiling:

`READ, ANALYZE, PLAN, BRANCH, COMMIT, PR, CI_REQUEST`

`MERGE, DEPLOY_REQUEST, PRODUCTION_MUTATION`, CRITICAL execution and reserved Owner mutation classes remain denied.

SA4 trust-root hardening

Before the first SA4 COMMIT/PR pilot, the SA1 self-authority ring was extended to include the SA3B/SA4 workflow, OIDC verifier, broker, mandates, parsers/host runner and audit adapter. A REM cannot authorize modification of those files even if an allowlist is maliciously widened.

SA2 — Chat execution profile

COMPLETE / VERIFIED PASS — PR #216 MERGED

Mutating SA2 LIVE remains denied. SA2 produces policy-bound envelopes; real mutation requires the later audit-bound execution permit.

Sequence requirements remain:

- fresh `agent/*` branch;
- full preflight;
- targeted validation before COMMIT;
- completed implementation + current head before PR;
- no silent mutation after final Owner review begins;
- no production mutation.

SA3A — Append-only audit adapter

COMPLETE / VERIFIED PASS — PR #218 MERGED

Canonical control:

SA1/SA2 ALLOW → durable M5 authorization event → auditReference → audit-bound permit → exact action → second append-only outcome event

SA3B — Execution-host binding

COMPLETE / VERIFIED PASS

Merged implementation:

- PR #220 host binding;
- PR #222 M5 writer/schema correction;
- final #222 merge 91963f59b74c8c3c3c0b33c6a23237a01ac0128e ;
- final #222 CI #951 PASS;
- corrected code deployed to Render.

Host architecture:

OWNER ISSUE → TRUSTED main WORKFLOW → STRICT REQUEST → GITHUB OIDC → CAPITAL-AI BROKER → SA1/SA2/SA3A → M5 PERMIT → GITHUB SIDE EFFECT → M5 OUTCOME

Real fail-closed proof

Issue #221 / run 31570833507 :

M5 PERSISTENCE FAILURE → NO PERMIT → NO BRANCH

Real positive proof

Issue #223 / run 31574111075 :

- exact current main: PASS;
- OIDC: PASS;
- durable authorization: PASS;
- audit-bound BRANCH permit: PASS;
- exact branch side effect: PASS;
- terminal outcome: PASS.

Authorization:

supabase:agent_audit_events:194f1198-492c-4d4f-b1e4-0c13a5d99d20

Outcome:

supabase:agent_audit_events:5ab9eefe-f472-4396-a7e7-2a3ceb029e34

Direct read-only Supabase verification confirmed the correlated rows, request/run/branch and authorization reference.

Separate stale-base proof

Issue #224 / run 31574221718 used stale base 156142102e7d2a97ad466aee0340f758fa4365e5 .

Result:

STALE BASE → DENY BEFORE OIDC/BROKER → NO BRANCH

Lifecycle closure

The successful probe branch agent/sa3b-host-probe-20260812b was deleted before the live SA4 pilot. The SA4 preflight therefore passed its fail-closed cleanup check before acquiring OIDC or requesting any mutation permit.

SA3B is complete only because both the positive permit-before-side-effect proof and the negative/fail-closed proofs are combined with successful branch cleanup.

SA4 — First bounded autonomous work-package REM

COMPLETE / VERIFIED PASS — PR #229 MERGED

Authority: ADR-0068 and .ai/mandates/REM-SA4-PIL0T-001.json .

Bounded pilot scope

The first pilot was deliberately documentation-only and one-time.

Exact output path:

docs/evidence/sa4/SA4_FIRST_AUTONOMOUS_WORK_PACKAGE.md

Allowed capabilities:

BRANCH → COMMIT → PR

Not delegated:

- CI_REQUEST ;
- merge;
- deploy;
- production mutation;
- repository protection changes;
- IAM/MFA/break-glass;
- secrets/credential rotation;
- billing;
- DNS/TLS.

Risk ceiling: MEDIUM .

Max open SA4/Systemadmin PRs: 1.

Mandate expiry: no more than seven days.

Kill switch: Owner-controlled and required.

SA4 live execution proof

Owner trigger:

- Issue #228;
- workflow run 31579519025 ;
- exact base main@f7dfcda36905d9a55d74f57f2140224928960379 ;
- pilot branch agent/sa4-pilot-proof-20260812b .

Autonomous repository result:

- BRANCH created only after a dedicated durable permit;
- deterministic evidence file generated from trusted host metadata;
- COMMIT 02f012e71106d5ffd9a4baa3e6f3eba7160eb55d created only after a separate COMMIT permit;
- committed bytes verified by SHA-256;
- Draft PR #229 created only after a separate PR permit;
- autonomous host requested no final CI, performed no deploy and performed no merge.

Durable M5 evidence

Capability	Authorization	Outcome	Result
BRANCH	supaba-se:agent_audit_events:1b4b04cb-a86b-4612-9ef5-308e95a18c95	supaba-se:agent_audit_events:c9b85102035d	SUCCESS e99b9af7-74cc-4693-966f-
COMMIT	supaba-se:agent_audit_events:3c5916a1-d8c1-4ba1-9de1-d839fcc1bc85	supaba-se:agent_audit_events:ae95-2c963a0776f5	SUCCESS bc6ecf0b-86db-4b8c-
PR	supaba-se:agent_audit_events:41874d2e-a7b7-48c9-8287-71d75-bea7d05	supaba-se:agent_audit_events:ab7d-f353880312ac	SUCCESS / PR #229 d4722de8-3242-4822-

All six rows share the same SA4 request/run correlation and preserve the permit-before-side-effect invariant.

Human final gate and lifecycle closure

- PR #229 changed exactly one file and one commit;

- Governance #662: SUCCESS;
- final CI #965: SUCCESS;
- Human/Owner current-head review and both attestations completed before final CI;
- Human merge completed on 2026-08-12;
- merge commit: `2e86d5fbc54f9b5ea2af4e6db33e9749c2ac15dd` ;
- pilot branch `agent/sa4-pilot-proof-20260812b` deleted after merge;
- trigger Issue #228 closed with reason `completed` after post-merge verification.

This proves the bounded autonomous chain:

Owner-approved REM → Owner Issue → trusted GitHub Actions host → OIDC → BRANCH permit/outcome → COMMIT permit/outcome → Draft-PR permit/outcome → Human review → final CI → Human merge → branch delete

SA4 VERIFIED PASS exit gate

1. fresh Owner `[SA4-PILOT]` Issue on exact current `main`: PASS;
2. BRANCH authorization + SUCCESS outcome persisted: PASS;
3. fresh pilot branch created from exact base SHA: PASS;
4. COMMIT authorization persisted before exact file write: PASS;
5. deterministic evidence file digest verified after commit: PASS;
6. COMMIT SUCCESS outcome persisted with exact commit SHA: PASS;
7. PR authorization persisted before Draft-PR creation: PASS;
8. Draft PR created from exact pilot commit: PASS;
9. PR SUCCESS outcome persisted with exact PR number: PASS;
10. no production mutation or autonomous CI/merge: PASS;
11. Human file review + final CI + Human merge: PASS;
12. pilot branch deleted after merge: PASS;
13. evidence and traceability synchronized: completed by the SA4 status-sync change set.

Next bounded repository work package — M5A Native MFA/AAL2

DRAFT / NOT ACTIVATED

Authority:

- `docs/roadmaps/M5A_SYSTEMADMIN_REPOSITORY_WORK_PACKAGE.md` ;
- `.ai/mandates/REM-M5A-REPOSITORY-001.json` ;
- ESS-0020 and ADR-0064.

The package reuses the verified SA4 repository execution chain for M5A code, tests and redacted evidence only. It does not introduce a new SA stage and does not widen SA4 authority.

Activation gates:

1. this documentation package is Human-reviewed and merged;
2. ESS-0020 and ADR-0064 are Human/Owner-accepted for repository implementation;
3. mandate is rebound to exact then-current `main`;
4. mandate status changes from `DRAFT` to `OWNER_APPROVED` with Approval Evidence;
5. SA preflight proves no path overlap, no stale base and durable audit availability.

Allowed:

`READ → ANALYZE → PLAN → BRANCH → bounded CODE/TEST/EVIDENCE → COMMIT → Draft PR → CI_REQUEST`

Denied:

- Supabase factor enrollment/removal/reset;
- production Auth/project configuration;
- secrets/recovery codes;
- Render/Stripe/IONOS;
- Ruleset/security-control weakening;
- merge and self-authority expansion.

After repository CI PASS, productive Owner-factor enrollment remains a separate Human/Owner M5A mutation gate. SA5 remains blocked until M10 `VERIFIED PASS`.

Nachtrag 2026-08-15 — generalized work-package catalog (ADR-0074)

Owner instruction to continue Systemadmin execution "codebasiert und dokumentenbasiert Anwendungsweit... über die Action Workflows", refined via `docs/architecture/GENERALIZED_SYSTEMADMIN_EXECUTION_HOST_DESIGN.md` to Model A (a catalog of pre-approved, already-reviewed work packages replayed through the same audited BRANCH/COMMIT/PR machinery SA4 proved) rather than Model B (runtime code generation — remains unsolved, see that document).

Like the M5A package above, this **does not introduce a new SA stage number** and does not widen SA4's proven authority — it generalizes the host machinery itself so a future work package needs only a new catalog module + a new Owner-approved REM (`REM-WORKPACKAGE-*` prefix), not an entirely new workflow file and broker route each time, as SA4 alone would have required.

- New generic host: `.github/workflows/systemadmin-work-package-runner.yml`, dormant by default (`if: false && ...`), same as SA4 before its own first activation.
- New catalog: `scripts/systemadmin/workPackages/registry.mjs` — currently exactly one entry, `GENERALIZATION-PROOF`, proving the machinery structurally works. `runSa4Pilot.mjs` itself is untouched; the new `runWorkPackage.mjs` duplicates its proven security pattern rather than refactor a verified-pass security path.
- First catalog mandate: `.ai/mandates/REM-WORKPACKAGE-GEN-PROOF-001.json`, **status DRAFT** — not Owner-approved by this session; independently unusable per SA1 `REM_SCOPE`

(`mandate.status !== 'OWNER_APPROVED'` denies) even if the dormant trigger were ever flipped.

- Both Systemadmin self-authority rings extended with every new file — see ADR-0074.
- Full contract test coverage: `tests/unit/systemadminWorkPackageCatalogContracts.test.ts` , `tests/unit/systemadminWorkPackageIssue.test.ts` , plus extended broker/OIDC tests proving SA3B/SA4 mandates cannot be used via the new workflow and vice versa.

Activation gates (mirrors SA4's, ADR-0074 Exit criteria): this PR Human-reviewed/merged; Owner separately flips the workflow's `if:` condition; Owner separately approves `REM-WORK-PACKAGE-GEN-PROOF-001` with a real `approvalEvidenceRef` ; a fresh Owner Issue then runs the proof end-to-end.

Status 2026-08-15: gate 1 (PR #321 merged) done. Gate 2 (workflow trigger) activated on explicit Owner instruction ("aktiviere den Work-Package-Runner") — `if: false && ...` removed from `.github/workflows/systemadmin-work-package-runner.yml` . Gate 3 (mandate approval) done on explicit Owner instruction ("fahre mit den Punkten 2 bis 4 fort") — `REM-WORKPACKAGE-GEN-PROOF-001` is now `status: OWNER_APPROVED` with `approvalEvidenceRef: "human-owner-chat-2026-08-15-workpackage-gen-proof"` , proven end-to-end via a real `evaluateSystemadminRoadmapAuthorization()` `ALLOW` test (`tests/unit/systemadminWorkPackageCatalogContracts.test.ts`).

Nachtrag 2026-08-15 — Gate 4 erfüllt, generalization COMPLETE / VERIFIED

PASS: the Owner opened Issue #325 (`[SYSTEMADMIN-WORK-PACKAGE]` , exact request JSON, `baseSha` matching current `main`) from the `SvenKulessa` account. The host ran the full audit-bound `BRANCH → COMMIT → PR` chain for real: branch `agent/systemadmin-work-package-gen-proof-1` , commit `e1ce748d9a4125777adeddac857603aff0c77ab3` , draft PR #326 with all six `supabase:agent_audit_events:*` authorization/outcome references. The Owner reviewed and merged PR #326 (merge commit `cb2db699ca7a2baf6cd9b4446aa7a2655d86ccdb`); the resulting push-to-main CI run (31894252190) passed. All 10 ADR-0074 exit criteria are met — see that ADR's own Nachtrag for the full point-by-point evidence. `GENERALIZATION-PROOF` is not deleted from the catalog (it is naturally self-blocking now via the `target-path-not-already-on-main` preflight check, and serves as a reference implementation for future catalog entries); the workflow trigger stays active, unlike SA4's one-time pilot.

SA5 — Bounded external mutation design

BLOCKED BY M10 VERIFIED PASS

SA4 is no longer a blocker. External production mutation remains prohibited until a separate future ADR proves exact-target, reversible execution plus strong M10 Owner assurance and M10 reaches runtime `VERIFIED PASS` .

Branch lifecycle

`current main → fresh scoped branch → audited actions → PR → Human review/CI → Human merge → branch delete`

Merged/superseded branches are never reused.

Current next action

M5A is VERIFIED PASS (2026-08-14, docs/evidence/m5a/M5A_VERIFIED_PASS_CLOSURE_EVIDENCE.md): both Owner identities completed native TOTP enrollment interactively; read-only production evidence confirms verified factors and aal2 sessions for both, and the Security Advisor shows no unowned HIGH/CRITICAL finding. The SA4 one-purpose host was never reused for M5A. M6 is now the next eligible DEVELOPMENT Chain gate; any M6 repository-code work is a separate, not-yet-issued mandate/task. SA5 remains blocked until M10 VERIFIED PASS.

Konsolidierter Prototyp- und Mutationsanfragepfad (PR #257)

Authority: docs/adr/ADR-0071-consolidated-roadmap-and-requested-systemadmin-mutations.md und .ai/skills/ESS-0023-Consolidated-Systemadmin-Prototype-and-Mutation-Request.md .

Der Systemadministrator-Agent darf aus der konsolidierten Roadmap begrenzte Prototypaufträge ableiten und notwendige Mutationen beim Owner anfragen. Eine Agentenanfrage ist niemals Approval. Externe, produktive, IAM-, Datenbank-, Billing-, Secret-, Deployment- oder HIGH/CRITICAL-Mutationen bleiben bis zur exakten Owner-Freigabe fail-closed.

Native MFA ist seit 2026-08-14 VERIFIED PASS — die anfängliche Owner-Attestation wurde durch read-only AAL2-, Faktor- und Advisor-Evidence gegen Produktion bestätigt (docs/evidence/m5a/M5A_VERIFIED_PASS_CLOSURE_EVIDENCE.md). SA5 bleibt bis M10 VERIFIED PASS blockiert.

Work Package SC-1 — Classification Consolidation

Quelle: docs/roadmaps/work-packages/SC-1_CLASSIFICATION_CONSOLIDATION.md

Work Package SC-1 — Classification Consolidation

SPT: SC-MD-SPT-0001

Priority: P0

Status: TABLE EXPANSION LANDED (deterministic coverage) — Owner review for merge

Date: 2026-08-15 / 2026-08-16

Problem

Three incompatible `CryptoClassification` definitions coexist:

Source	Shape
<code>src/types/crypto.types.ts</code>	Canonical 25-value <code>CryptoCategory</code> + tier
<code>src/types/crypto.ts</code>	Legacy <code>"Crypto" \ "Unknown"</code>
<code>src/agents/cryptoClassificationAgent.ts</code>	Free-text <code>category / sub_tier</code>

Historically `ClassificationService` only hard-coded ~20 symbols.

Delivered in this WP

- [x] `src/services/classificationAdapter.ts` — pure adapter + merge
- [x] Wire adapter into `cryptoOrchestrator` as single classification exit
- [x] Unit tests adapter + merge
- [x] Baseline + wiring evidence under `docs/evidence/sc-md/`
- [x] **Expand deterministic `ClassificationService` table** (table-driven; Stablecoin, RWA, AI/Data, L2, Oracle, Liquid Staking, Gaming, Storage, Privacy, Payments, Exchange, ...)
- [x] Unit tests `tests/unit/classificationServiceTable.test.ts`

Explicitly NOT done

- [] Deprecate / rename agent interface to `AgentCryptoClassificationRaw` at all import sites
- [] Delete or archive unused legacy type fields after full consumer audit
- [] SC-7 ranking writeback of composite DQ (separate Owner gate)

DoD (full SC-1)

1. One canonical schema for all crypto scoring/ranking consumers
2. Adapter used at orchestrator boundary

3. No free-text category values in ranking payloads
4. Tests green; no ranking formula change
5. Deterministic table covers core categories beyond legacy ~20 symbols
6. Evidence note under `docs/evidence/sc-md/`

Risk

Low: additive table rows; fail-closed Unknown retained; no ranking formula mutation.

Work Package SC-3 — Unified DQ + Confidence Composite

Quelle: docs/roadmaps/work-packages/SC-3_UNIFIED_DQ_CONFIDENCE.md

Work Package SC-3 — Unified DQ + Confidence Composite

SPT: SC-MD-SPT-0001

Priority: P0

Status: FOUNDATION LANDED + SC-7 PHASE A CONSUMER MAPPING

Date: 2026-08-15 / 2026-08-16

Problem

- `DataQualityService` assesses **snapshot** quality (LIVE/STALE/INVALID) only.
- Ranking used a coarse `data_quality.level` → 100/70/40/50 mapping (duplicated).
- Completeness ratios exist per scoring engine but are not one platform composite.
- `scoreConfidenceCalibration` is empirical hit-rate with `scoreImpactEnabled: false`.

Delivered

- [X] `src/platform/MarketData/CompositeDataQuality.ts`
- `computeCompositeDataQuality`
- `computeUnifiedConfidence` (**scoreImpactEnabled: false**)
- `compositeLevelToRankingDqPoints` helper
- [X] Unit tests `tests/unit/compositeDataQuality.test.ts`
- [X] **SC-7 Phase A:** `ranking.service` resolves DQ points via `compositeLevelToRankingDqPoints` + optional `compositeLevel` (same map; **RANKING_SCORE_IMPACT_ENABLED = false**)

Explicitly NOT done

- [] Enable `scoreImpact` / `recommendationImpact` / `rankingImpact`
- [] Persist composite on every score payload as mandatory field
- [] Wire `MarketDataGateway` snapshots automatically into composite at every orchestrator path
- [] Change ranking formula weights

DoD (full SC-3 + ranking writeback)

1. Single composite contract versioned
2. Ranking consumers opt-in without dual formulas ← **Phase A done**
3. Confidence never silently inflates scores until Owner sets impact flags

4. Tests cover missing-factor renormalization and INVALID snapshot cap
5. Evidence under `docs/evidence/sc-md/`

Risk

Foundation and Phase A mapping are fail-closed / parity-preserving. Enabling ranking **impact** remains a separate governed mutation.

Work Package SC-4 — Gateway Hardening & Provider Matrix

Quelle: docs/roadmaps/work-packages/SC-4_GATEWAY_HARDENING_PROVIDER_MATRIX.md

Work Package SC-4 — Gateway Hardening & Provider Matrix

SPT: SC-MD-SPT-0001

Priority: P1

Status: PHASE A LANDED — matrix + per-provider RL + gateway→supervisor health

Date: 2026-08-16

Goal

Alle **bekannten** Live-Provider und ihre Control-Plane-Parameter (Rate-Limit, Circuit Breaker, Gateway-Status) sind in einer kanonischen Matrix dokumentiert und an den MarketDataGateway angebunden. Supervisor sieht Gateway-Outcomes als Provider-Health.

Delivered (Phase A)

- [x] `src/platform/MarketData/ProviderMatrix.ts` — kanonische Matrix (TwelveData, FMP Index, Alpaca shadow, FMP History, CoinGecko/Stooq legacy)
- [x] `RateLimitBudget.perProvider` — capacity/window pro Provider-ID
- [x] Default-Gateway-Budget aus Matrix (`rateLimitOverridesFromMatrix`)
- [x] `CircuitBreaker.openedUntilIso` für Supervisor `circuitOpenUntil`
- [x] `MarketDataGateway` schreibt `recordProviderHealth` bei success / failure / rate-limit / circuit-open
- [x] `traditionalQuoteEvidence` nutzt Matrix-Budgets auf TwelveData- und FMP-Index-Gateway-Pfaden
- [x] Unit tests `tests/unit/providerMatrix.test.ts`
- [x] Evidence unter `docs/evidence/sc-md/`

Explicitly NOT done (follow-ups)

- [] Crypto Live-Pfade (CoinGecko etc.) hinter Gateway migrieren → **SC-5**
- [] Alpaca role `primary` Promotion (ADR-0041 Owner gate + 14-day evidence)
- [] History-Gateway CB/RL parity (P3C activation still Owner-gated)
- [] Per-provider CircuitBreaker threshold from matrix at construction (global defaults remain; matrix documents intended values)
- [] MCP plane / Alpha Vantage adapter

DoD Phase A

1. Matrix listet gateway-relevant providers mit RL/CB

2. Behind-gateway providers (TwelveData, FMP Index) nutzen Matrix-Budgets
3. Supervisor Health erhält Gateway-Outcomes ohne Provider-Payloads
4. Legacy-off-gateway providers sind inventarisiert, nicht still migriert
5. Tests grün; keine scoreImpact-/Scoring-Mutation

Risk

Niedrig-mittel: engere Rate-Limits können bei Last häufiger `rate_limited` / `UNAVAILABLE` erzeugen — fail-closed, kein Synthetic Fallback.

Work Package SC-5 — Live Coverage Expansion

Quelle: docs/roadmaps/work-packages/SC-5_LIVE_COVERAGE_EXPANSION.md

Work Package SC-5 — Live Coverage Expansion

SPT: SC-MD-SPT-0001

Priority: P1

Status: PHASE B IN PROGRESS — multi-field snapshot matrix RL/CB aligned

Date: 2026-08-16

Goal

Verified live quotes for **Stock / FX / Index / Crypto** with fail-closed status, central CB/RL/cache via MarketDataGateway, and an explicit live-coverage matrix.

Delivered (Phase A)

- [x] `CoinGeckoMarketDataProvider` — price-only canonical crypto snapshot
- [x] `fetchVerifiedCryptoQuote` (`crypto-quote/1.0.0`) through MarketDataGateway
- [x] ProviderMatrix: `coingecko` → `behind_gateway`; CoinAPI/EODHD inventoried as `consensus_only`
- [x] Live coverage matrix doc under `docs/evidence/sc-md/`
- [x] Unit tests: provider + evidence fail-closed paths
- [x] Stock / FX / Index remain on traditionalQuoteEvidence (already gateway, SC-4)

Delivered (Phase B)

- [x] Multi-field `cryptoSnapshotProvider` uses ProviderMatrix `coingecko` rate-limit + circuit-breaker policies
- [x] Capability key `market-fields`; Supervisor health on success / rate-limit / open circuit
- [x] Fail-closed: budget exhaustion or open CB → last-known-good (degraded) or null; no registry bootstrap
- [x] `VerifiedCryptoSnapshot` API unchanged (scoring callers stable)
- [x] ProviderMatrix version `provider-matrix/1.2.0` + notes
- [x] Unit tests for rate-limit and circuit-open paths

Explicitly NOT done

- [] Map marketCap/supply into `CanonicalMarketDataSnapshot` / full gateway `getSnapshot` path
- [] Register CoinAPI/TwelveData/EODHD as gateway crypto adapters for quorum

- [] Wire `executionPriceEligible: true` for crypto (requires multi-provider quorum + Owner)
- [] Stooq behind gateway
- [] Alpaca primary promotion
- [] scoreImpact / rankingImpact flip
- [] Change scoring formulas or eligibility thresholds
- [] Process-wide shared RateLimitBudget instance between gateway quote path and multi-field path (policies aligned; instances still separate)

DoD Phase B

1. Multi-field CoinGecko path consumes matrix RL capacity and CB thresholds
2. Rate-limit / open circuit → no synthetic fields; degraded last-known-good or null
3. Evidence + work-claim updated
4. Existing provenance + cache-hit behaviour preserved
5. Tests green

Risk

Niedrig: additive policy wiring. Callers of `getVerifiedCryptoSnapshot` unchanged. No eligibility or scoreImpact mutation.

Work Package SC-7 — Ranking Composite Opt-In

Quelle: docs/roadmaps/work-packages/SC-7_RANKING_COMPOSITE_OPT_IN.md

Work Package SC-7 — Ranking Composite Opt-In

SPT: SC-MD-SPT-0001

Priority: P1

Status: PHASE A + PHASE B LANDED — orchestrator wires compositeLevel; scoreImpact still false

Date: 2026-08-16

Goal

Ranking resolves DQ contribution points via the SC-3 helper `compositeLevelToRankingDqPoints` instead of a duplicated inline ternary.

Optional `RankingDqOptions.compositeLevel` lets callers that already computed a composite pass the level explicitly — **same 100/70/40/50 map**, same formula weights.

Delivered

Phase A

- [x] `resolveRankingDqPoints` in `ranking.service.ts`
- [x] `calculateRankScore(..., options?)` optional composite level
- [x] `RANKING_SCORE_IMPACT_ENABLED = false` explicit constant
- [x] Unit tests: parity payload level ↔ compositeLevel; formula regression (92 for high/tier1 case)
- [x] Evidence under `docs/evidence/sc-md/`

Phase B (this commit)

- [x] `cryptoOrchestrator.analyzeCrypto` passes `{ compositeLevel: composite.level }` into `calculateRankScore`
- [x] Reasoning trail documents SC-7 Phase B + impact-off posture
- [x] Pure SC-3 level used for rank DQ points (unknown → 50 fail-closed)
- [x] Evidence `SC7_PHASE_B_ORCHESTRATOR_WIRING_2026-08-16.md`

Explicitly NOT done (Owner gates)

- [] Flip `scoreImpactEnabled` / `rankingImpactEnabled` to true
- [] Change formula weights (0.70 / 0.15 / 0.10 / 0.05)
- [] Cross-asset rank modes (Overall / Category / Tier / Growth)

- [] Mandatory composite persistence on every payload
- [] Wire valuation.service / cryptoRoutes list|score|top10 (still payload-level path; no SC-3 composite there yet)

DoD Phase A + B

1. One DQ point map shared with SC-3
2. Existing consumers without options behave identically
3. Orchestrator (primary multi-agent path) uses composite opt-in
4. Tests prove numerical parity for explicit compositeLevel
5. No silent score inflation flags

Risk

Low-medium: Phase B uses pure `composite.level` for ranking points. When composite is `unknown`, rank DQ points are **50** (fail-closed) rather than the display rewrite on `payload.data_quality` (medium/high). Formula weights and eligibility thresholds unchanged. `scoreImpact` remains false.